

UNCLASSIFIED

United States Navy

RISK MANAGEMENT FRAMEWORK PROCESS GUIDE

Version 4.0

Distribution Statement D: Distribution authorized to the Department of Defense and U.S. DoD contractors only determined 12 August 2015. Other requests will be referred to DON Deputy CIO (Navy) Directorate.

Ms. Megan Cane
Deputy Director, Department of the Navy (DON) Deputy CIO (Navy) Directorate
5 March 2024

UNCLASSIFIED

UNCLASSIFIED

THIS PAGE INTENTIONALLY LEFT BLANK

UNCLASSIFIED

RECORD OF CHANGES

The table below is used to record revisions to this document. The version number, date and description of change for each revision are noted in the table.

Version Number	Date of Issue	Section(s)	Brief Description of Revision
1.0	15 December 2016		
2.0	04 August 2017	All	Added DDCIO(N) SharePoint site, new appendices, and additional RMF references
3.0	27 September 2018	All	Full re-write. Roles, responsibilities, and processes revised to reflect USN RMF changes.
3.1	03 February 2020	Appendix K	Appendix updated to reflect the streamlined IATT process.
3.2	2 September 2020	4.2, 4.4, 4.5, Appendix K, Appendix J	Decisions from January 2020 RMF Reform Offsite implemented. Categorization workflow, Checkpoint 2, and Checkpoint 5 made optional. Final SAR moved to Step 4. Standardized change communication process. Updated diagrams.
3.3	30 October 2021	Appendix M, Appendix N	Added Appendix M, "Streamlined RMF Review Process," and Appendix N, "Reauthorization upon ATO Expiration Guide"
4.0	XX July 2023	All	Full re-write. Introduces a streamlined Cyber Currency process for security updates. Removal of Categorization Form as a separate requirement. Adds detailed language around definitions of risk levels. Incorporates eMASS Assets tab into RMF documentation requirements.

Direct any questions and concerns about this guide to the [DON Deputy Chief Information Officer \(Navy\) \(DDCIO \(N\)\)](#) or the applicable Authorizing Official. This guide is an evolving document that will continue to be updated as lessons are learned and processes are improved.

Version control is maintained on the [USN RMF Portal](#) (<https://portal.secnav.navy.mil/orgs/OPNAV/N2N6/DDCION/N2N6BC4/RMF>).

TABLE OF CONTENTS

Section 1: Introduction.....	6
1.1. Purpose.....	6
1.2. Scope.....	7
1.3. Background	7
Section 2: Navy RMF Roles and Responsibilities.....	8
2.1. RMF Personnel Qualifications.....	9
2.2. RMF Communication Chain.....	9
2.3. RMF Role Descriptions	9
Section 3: Authorization Methods	18
3.1. Authorization Categories	18
3.2. Assess Only Categories	18
3.3. Reciprocity	18
3.4. Authorization with Special Considerations	19
3.5. Rapid Assess and Incorporate Software Engineering (RAISE).....	21
Section 4: The Navy RMF Process	22
4.1. RMF Step 1 - Categorize System	22
4.2. RMF Step 2 - Select Security Controls.....	26
4.3. RMF Step 3 - Implement Security Controls	33
4.4. RMF Step 4 - Assess Security Controls.....	36
4.5. RMF Step 5 - Authorize System	43
4.6. RMF Step 6 - Monitor Security Controls	48
Section 5: Lifecycle Maintenance.....	49
5.1. Maintain Authorization.....	49
5.2. Maintaining Cyber Currency	50
5.3. Annual Security Review	50
5.4. Decommissioning.....	52
5.5. Expiring A&A Management Process	53
References.....	54
Glossary	56
Acronyms.....	58
Appendix A - RMF Minimum Package Requirements.....	61
Appendix B - Security Plan	63
Appendix C - Security Assessment Plan Template	69
Appendix D - Security Assessment Report Template	69
Appendix E - Plan of Actions and Milestones Template.....	72

Appendix F - SLCM Strategy	76
Appendix G - Authorization Options Guide	79
Appendix H - Navy Checkpoint Process and Requirements	82
Appendix I - IATT RMF Process Modifications	84
Appendix J - Financial Management Overlay	93
Appendix K - Streamlined Risk Management Framework (RMF) Review Process	97
Appendix L - Streamlined Reauthorization Process	99

TABLES

Table 1. Navy RMF Roles	8
Table 2. Special System Considerations and Guidance	20
Table 3. RASC - Categorize System	22
Table 4. Step 1 Inputs, Outputs, and Required Tools	23
Table 5. Impact Values	24
Table 6. RASC - Select Security Controls and SLCM Strategy	26
Table 7. Inputs, Outputs, and Required Tools of RMF Step 2	27
Table 8. Common Control Sources	29
Table 9. RASC - Implement Security Controls	34
Table 10. Inputs, Outputs, and Required Tools of RMF Step 3	34
Table 11. RASC - Assess Security Controls	37
Table 12. Inputs, Outputs, and Required Tools of RMF Step 4	39
Table 13. RASC - Authorize System	43
Table 14. Inputs, Outputs, and Required Tools of RMF Step 5	44
Table 15. RASC –Monitor Security Controls	49
Table 16 . Inputs, Outputs, and Required Tools of RMF Step 6	49
Table 17. Navy RMF Required Documentation	61
Table 18. Applicable Security Controls for IATT	88
Table 19. RMF IATT Authorization Process Steps	90
Table 20. FM Document Guide	96

FIGURES

Figure 1. eMASS Risk Assessment screen	70
Figure 2. IATT Profiles	87
Figure 3. IATT Workflow with Processing Timelines	90
Figure 4. FM Audit-Relevant System Inventory	94
Figure 5: Step 2 Streamlined Risk Management Framework Review Process	98
Figure 6: Step 5 Streamlined Risk Management Framework Review Process	98

Section 1: Introduction

The Risk Management Framework (RMF) for Department of Defense (DoD) Information Technology (IT) mandates the management of cybersecurity risk across the enterprise through adaptation of the National Institute of Standards and Technology (NIST) Special Publication 800-37, *Guide For Applying The Risk Management Framework To Federal Information Systems* (reference (p)). RMF uses a risk-based cybersecurity approach for enterprise-level authorization of IT systems and services. The RMF implements and enforces a tailored set of security controls (references (d) and (o)), and focuses on security as an integral part of a system's overall lifecycle. The Department of Navy (DON) Deputy CIO (Navy) (DDCIO(N)) maintains all authoritative United States Navy (USN) RMF policy, guidance, and templates on the [USN RMF Portal](#). Echelon 2 organizations may host organization-specific implementation guidance and resources on their own portals; however their guidance may neither conflict with requirements outlined in this guide nor introduce new process or documentation requirements.

In alignment with references (a) and (p) RMF must be indistinguishable from routine System Development Life Cycle (SDLC) practices to the maximum extent feasible. DoD RMF Security Controls as outlined in reference (a) will be referred to as cybersecurity requirements and cybersecurity solutions per DoD's acquisition guidelines. Cyber requirements generated by RMF controls must be allocated, implemented, and tested throughout system design, development, production, deployment, and sustainment. Failed cyber requirements and/or discovered vulnerabilities will be tracked along with all other failed requirements and/or system defects.

To further clarify reference (a), the RMF authorization package will leverage data that represents current operating environment. Data collected can be part of systems engineering and/or application development processes. Use of the templates provided on the Navy RMF portal are optional to meet the intent of RMF, but can be replaced by leveraging existing systems engineering or acquisition documentation with the same data points. Leveraged body of evidence must be usable by RMF and uploaded into eMASS.

1.1. Purpose

This guide provides the Navy-specific processes to execute the DoD Instruction (DoDI) 8510.01, *Risk Management Framework (RMF) for DoD Information Technology (IT)* (reference (a)) and DoDI 8500.01, *Cybersecurity* (reference (c)), within the USN GENSER governance structure. This guide also establishes key roles and responsibilities for RMF stakeholders and provides them with practical guidance for executing all the functions of RMF.

This guide is intended for all United States Navy (USN) IT as defined by the Deputy DON Senior Information Security Officer (SISO) (Navy) (DDSISO(N)), assigned Security Control Assessor (SCA) and Authorizing Official (AO) Areas of Responsibility (AORs). For the purposes of this guide and in alignment with reference (a), IT is the collective term that encompasses IS, OT, industrial control systems, IT products, IT services (to include cloud services), and any other IT asset to include: facility related control systems, combat and weapons systems; navigation systems; propulsion systems; and hull, mechanical, and electrical systems; and infrastructures or software contractually operated on behalf of the USN.

1.2. Scope

This guide applies to all Navy IT – without exception – that operate at the General Service (GENSER) Top Secret level and below. Specialized Assessment & Authorization (A&A) paths within USN RMF are defined explicitly throughout this guide. This guide is not tool dependent and is not meant to be a manual or training guide for Enterprise Mission Assurance Support Service (eMASS). This guide is written for users with a basic knowledge of Navy cybersecurity and A&A.

This guide complements the RMF eMASS Functionality Guide and eMASS Job Aids in providing implementation guidance to support reference (a). The eMASS Functionality Guide and eMASS Job Aids (or alternative guidance from the cognizant Authorizing Official) should be followed unless there is a direct conflict with this guide. This guide may be added to, modified, or tailored via official correspondence from DDCIO(N) or DDSISO(N) to meet the dynamic needs of the Fleet. The terms “Navy”, and “USN” are used frequently throughout this guide and refer to the United States Navy, not the Department of the Navy. The Naval Intelligence Activity (NIA) Authorizing Official (AO) provides RMF guidance for Navy IT that processes information at the Sensitive Compartmented Information (SCI) and Controlled Access Program information in support of the Navy Intelligence mission

1.3. Background

References (a) and (c) establish the DoD Assessment and Authorization (A&A) model to comply with updated Federal directives, including the Committee on National Security Systems Instruction (CNSSI) 1253, *Security Categorization and Control Selection for National Security Systems* (reference (d)); Federal Information Processing Standard Publication (FIPS Pub) 199, *Standards for Security Categorization of Federal Information and Information Systems* (reference e); and multiple NIST Special Publications 800 series guidelines. These references are targeted at strengthening organizational cybersecurity posture, shifting organizations from compliance checks to a continuous risk management program, and encouraging system-level cybersecurity reciprocity (mirroring the risk decision of another organization in like environments) amongst federal agencies.

The CNO (N2N6) memorandum *US Navy Information Security Continuous Monitoring Program* (reference (t)) establishes the USN Information Security Continuous Monitoring (ISCM) Program.¹

For the purposes of this document the terms Plan of Action and Milestones (POA&M) and Corrective Action Plan (CAP) are used interchangeably.

¹ DoD and DON are separating System Level Continuous Monitoring (SLCM) from ISCM in that SLCM is meant to define the continuous monitoring from a system-level (i.e. individual package) perspective, and ISCM will refer to a given enterprise-level strategy – Navy, DON, DoD, or otherwise.

Section 2: Navy RMF Roles and Responsibilities

This section describes the roles, responsibilities, required qualifications for each role, and the proper chain of command for programs to request guidance or special consideration under the Navy's RMF taxonomy to ensure due diligence in Navy systems' cybersecurity.

Table 1 identifies the Navy-assigned RMF roles by appointment, consistent with reference (c), as well as the Navy RMF Process Guide (RPG) terminology used for each role:

Table 1. Navy RMF Roles

DoD RMF Role	Navy RPG Term	Appointed By	Navy Assignment
Authorizing Official (AO)	AO	CNO (N2N6)	Navy Authorizing Official (NAO), Functional Authorizing Officials (FAO)
Authorizing Official Designated Representative (AODR)	AO Cybersecurity Analyst (CSA)	AO	AO-approved representatives (optional)
DoD Component /Service Senior Information Security Officer (SISO)	DON Deputy SISO (Navy) (DDSISO(N))	DON SISO	DDSISO(N)
Security Control Assessor (SCA)	SCA	CNO (N2N6)	Navy SCA, Functional SCAs (FSCA)
-----	SCA Liaison	SCA	SCA-L, FSCA-L, SCA-approved representatives
-----	Validator	SCA	Navy SCA-Approved Navy Qualified Validator (NQV)
Program Manager (PM)/ System Owner (SO)	PM/SO	System-specific	System-specific
Information System Security Manager (ISSM)/ Information System Security Officer (ISSO)	ISSM/ISSO	PM/SO/Commanding Officer (system-dependent)	System-specific
Information System Security Engineer (ISSE)	ISSE	PM/SO	System-specific
User Representative (UR)	UR	PM/SO	System-specific
-----	Package Submitting Officer (PSO)	Echelon 2 Commander	Echelon 2-specific

2.1. RMF Personnel Qualifications

Personnel serving in RMF roles are required to meet the suitability and eligibility requirements established in references (f), (g), (h), and (i), in addition to qualification standards in Federal, DoD, and Navy policy. The personnel supporting RMF must have knowledge of the IT portfolio which they are assigned to.

2.2. RMF Communication Chain

In order to ensure transparency and consistency within the RMF process with regard to seeking specific assistance in resolving any issues that may arise, programs should reach out to their assigned PSO prior to reaching out to their cognizant SCA and AO.

For Navy-wide changes or updates, OPNAV will post announcements on the USN RMF Portal and an update will be posted to the eMASS bulletin board. For the sake of convenience, the USN RMF Portal located at

<https://portal.secnav.navy.mil/orgs/OPNAV/N2N6/DDCION/N2N6BC4/RMF/> has a button to subscribe to new announcements.

2.3. RMF Role Descriptions

2.3.1. Authorizing Official (AO)

The AO is exclusively accountable for organizational cybersecurity risk exposure corresponding to all IT under their cognizant authority. Therefore, the AO is exclusively responsible for making risk decisions for all IT that are requested to operate under their cognizant authority. The AO makes an authorization decision based on all the artifacts related to the activities within the RMF process and in accordance with the AO's cybersecurity risk tolerance. This risk tolerance accounts for the risk of exploitation which is the likelihood of a breach to confidentiality, integrity, and availability of information and the potential impact that breach would conceivably have on Navy operations and assets, individuals, other organizations, and the nation. Potential impact of breaches range from the unintentional release of Controlled Unclassified Information (CUI), loss of access to mission-critical information and assets, to loss of life and everything in between. The Navy construct utilizes both the NAO and FAOs for specific responsibilities. The generic term "AO" is used throughout this guide to represent the cognizant AO for any given IT portfolio unless otherwise specified. The cognizance of the AOs is defined in reference (af), the OPNAVINST 5239.1D, *US Navy Cybersecurity Program*.

The AO's responsibilities are to:

- Make authorization decisions for systems to operate considering the risk assessment, system operational context, and mission need
- Consider the impact of any cross domain issues in the overall authorization decision
- Render a final acceptance of the risk determination submitted by the SCA of the risk to Navy operations, assets, individuals, other organizations, and the nation from the operation and use of the system
- Review and reciprocate risk decisions made by other DoD Services and Federal Agencies except where extenuating circumstances exist – the AO must justify any decision to decline reciprocal risk acceptance to DDCIO(N) articulating such circumstance per reference (af), the OPNAVINST 5239.1D.
- Oversee all risk management activities for which they have cognizance

- Approve programs' Security Plan (SP) and System Level Continuous Monitoring (SLCM) Strategy (may delegate to CSA)
- Monitor and track overall execution of Plan of Actions and Milestones (POA&M)/Corrective Action Plan (CAP) and holds the PM/SO accountable for ensuring due diligence in execution
- Issue Authorization to Operate (ATO), ATO with Conditions (High/Very High residual risk systems require the approval of DON CIO prior to authorization issuance), Interim Authorization to Test (IATT), Authorization to Connect (ATC), or Denial of Authorization to Operate (DATO) for every program assessed and authorized through the RMF process
- Utilize the Collaboration Board in eMASS for all formal coordination during the RMF process. If not included within the collaboration board, detailed findings will be posted in the Artifacts tab (if necessary).

2.3.2. Authorizing Official Cybersecurity Analyst (AO CSA, optional role)

The AO may designate a team of AO CSAs to assist with certain AO responsibilities. In the absence of AO CSAs, AOs will assume all AO CSA responsibilities.

The AO CSA's responsibilities are to:

- Review the SP, SLCM Strategy, and Security Assessment Report (SAR) Executive Summary submitted by the PM/SO (or by someone else on their behalf) and SCA and provide recommendations to the AO
- Participate when PSO or programs opt to have Checkpoint meetings (described in Appendix H), attend and provide RMF Subject Matter Expert (SME) guidance and initial approval on behalf of the AO
- Ensure authorization requests are supported by sufficient documentation as outlined in the required RMF Standard Operating Procedures (SOP)
- Ensure authorization recommendations comply with higher level policy as defined by DoD/Navy policy, instruction, and guidelines in support of the AO authorization decision
- Provide technical analysis of RMF artifacts to inform the authorization decision in support of the AO
- Support the monitoring and tracking of POA&Ms/CAP
- Review the SCA assessment of POA&M/CAP vulnerabilities and failed security controls and provide recommendations to the AO on acceptance of risk
- Utilize the Collaboration Board in the eMASS workflow for all formal coordination during the RMF process. Detailed findings will be posted in the Artifacts tab (if necessary).

2.3.3. Security Control Assessor (SCA)

The Security Control Assessor (SCA) oversees the RMF cybersecurity risk assessment process which determines residual cybersecurity risk after taking into account technical architecture and cybersecurity protection of system-of-systems in support of an RMF authorization. To determine the overall effectiveness of the security controls at mitigating risk, the SCA performs an independent, holistic assessment of the management, operational, and technical controls employed within or inherited by a Navy system. To perform the SCA function in the most efficient manner, the SCAs will utilize SCA Liaisons and Validators to assist with SCA

responsibilities. The Navy construct utilizes both the Navy SCA, for systems under NAO's portfolio, and FSCAs, for systems under the FAOs' portfolios. The generic term "SCA" is used throughout this guide to represent the SCA (either Navy SCA or FSCA) for any given IT portfolio unless otherwise specified. The Cybersecurity Technical Authority (CS TA) issues a Technical Process Owner (TPO) Technical Warrant to each SCA. The appointed SCA can choose to delegate SCA responsibilities to any person holding a Technical Warrant designating them a Technical Area Expert (TAE), however SCA signature authority cannot be delegated below the FO/SES level.

The SCA's responsibilities are to:

- Assess and quantify aggregate cybersecurity risk using metrics consistent with Navy guidance for both inherent system residual risks and system accessibility related risks
- Perform a holistic cybersecurity risk assessment based on the POA&M/CAP, vulnerabilities, operating environment, system-of-system protections, and other available supporting documentation (e.g., cyber test and evaluation (T&E) results, Defense in Depth Analysis, etc.)
- Consider the impact of any cross domain solutions as assessed by the Cross Domain Technical Advisory Board (CDTAB)
- Consider the impact of any cross domain interfaces as assessed by the Navy Cross Domain Solution Office (NCDSO) and approved by DDSISO(N).
- Produce the RMF risk determination via the SAR following all requirements outlined in the SOPs, and make a recommendation to the AO regarding system authorization
- Complete the SAR Executive Summary, which must clearly communicate the SCA's assessment of overall risk, key drivers for the risk assessment, and the overall cybersecurity posture of the system in the operational environment within which it is deployed
- Sign the SAR in eMASS
- Utilize the Collaboration Board in the eMASS workflow for all formal coordination during the RMF process. Detailed findings will be posted in the Artifacts tab (if necessary).
- Approve qualified SCA Liaisons
- Appoint and assign qualified SCA Liaisons for respective areas
- Establish minimum qualifications for Validators (Navy SCA only)
- Authorize Validators (reference (j))

2.3.4. SCA Liaison

The SCAs may utilize a team of SCA Liaisons to assist with SCA responsibilities. The SCA Liaison will interface with the PM/SOs, ISSMs, ISSEs, Validators, PSOs, and AO CSAs as a representative of the SCA. The SCA Liaison should be a risk assessment SME and provide support and assistance in the A&A effort.

The SCA Liaison's responsibilities are to:

- Assess approved technical and non-technical security features of a system or network to address known threats and vulnerabilities in accordance with the approved Security Assessment Plan (SAP)
- Independently recommend aggregate cybersecurity risk assessment to the SCA

- Participate when PSO or programs opt to have Checkpoint meetings (described in Appendix H), and provide RMF Subject Matter Expert (SME) guidance and initial approval on behalf of the SCA.
- Provide initial concurrence on the SAP
- Provide approval recommendation of the SAR to the SCA
- Review and assess individual vulnerabilities in the POA&M, ensuring the appropriate residual risk.
- Utilize the Collaboration Board in the eMASS workflow for all formal coordination during the RMF process. Detailed findings will be posted in the Artifacts tab (if necessary).
- Review and concur/non-concur with the Validator's residual risk assessment
- Provide guidance to Validators on the following:
 - Understanding of the RMF risk assessment process as outlined in the Step 4 SOP
 - Knowledge of implementation and applicability of security controls
 - Use of appropriate test procedures and tools
 - Mitigation measures for specific vulnerabilities
 - Traceability of test results to system components and the risk assessment, as reflected in the relevant RMF documentation
 - Understand policies and their effects on the risk of a system

2.3.5. Validator

To assist the Navy SCA in performing risk assessments, the Navy utilizes Navy Qualified Validators (NQV). The NQV is solely responsible for assessing the system that is provided – not for developing the Security Authorization Package or engineering the system. The NQV acts as an extension of the SCA and cannot perform any other role on an RMF Security Authorization Package for which they are listed as the NQV. The NQV should utilize the SCA as an advisor to assist in all matters of validation, documentation, vulnerability mitigation, and residual risk determination. The PM/SO must fund the NQV, but the Navy SCA provides the list from which the PM/SO selects the individual per reference (j).

All NQVs providing input to a RMF Security Authorization Package must be identified as Validators in eMASS. Once validation is complete and a SAR has been generated, the validation efforts for the Security Authorization Package will be scored utilizing a Proficiency Tracking Record (PTR). PTRs are maintained by the Navy SCA. An NQV credential remains valid as long as the maintenance requirements defined and published by the Navy SCA are met and the NQV maintains a proficiency documented by the Navy SCA.

The Validator's responsibilities are to:

- Prepare and submit the SAP with program assistance
- Execute the approved SAP
- Perform a complete assessment of a system's or network's security controls, known threats, and vulnerabilities
- Ensure traceability of all vulnerabilities from raw assessment results to the POA&M
- Provide a summary of failed controls in Risk Assessment tab in eMASS
- Recommends updates to the POA&M based on the assessment results
- Complete a SAR, in conjunction with the SCA, based on the assessment results

- Prepare the SAR Executive Summary, with all assessment results, for SCA review
- Utilize the Collaboration Board in the eMASS workflow for all formal coordination during the RMF process. Detailed findings will be posted in the Artifacts tab (if necessary).

2.3.6. Navy Package Submitting Officer (PSO)

The PSO and their staff are the responsible cybersecurity officials within the echelon 2 Command Information Office or Program Executive Offices (PEOs).

PSOs are required to report data and metrics to the echelon 2 Command Information Office to ensure compliancy with all Command Information Office-related tasking, including but not limited to DON Application and Database Management System (DADMS) and Department of Defense Information Technology Portfolio Repository – Department of the Navy (DITPR-DON) registration, DoD Cyber Hygiene Scorecard reporting, and Vulnerability Remediation Asset Manager (VRAM) Registration/Compliancy.

The PSO is responsible for prioritizing, enforcing standardization, and performing quality assurance reviews prior to establishing checkpoints (in the event that they opt to have checkpoints).

The PSO's responsibilities are to:

- Review the System Categorization for every system in its respective IT portfolio
- Perform a quality assurance review for RMF Steps 1, 2, 5 & 6.
- Coordinate package priority changes with the cognizant AO based on mission criticality and impact date for review and processing
- Communicate with all RMF stakeholders throughout the RMF process in an agreed upon format initially defined by the PSO
- Perform all coordinating functions with the SCA Liaisons and the AO CSAs for Security Authorization Package review, processing requirements and issues
- Coordinate with the program on documentation of findings identified during the review process
- Coordinate with the cognizant AO to ensure all systems/networks in their portfolio are operating with the required authorization
- Establish PSO business rules in coordination with key stakeholders for A&A processing within the domain that governs specific actions/internal processes unique to the command
- Coordinate with the PM/SO to provide status of authorization conditions within required timelines as stated in authorization document and as requested by the AO
- Coordinate with the cognizant AO to ensure the PMs report on status of authorization stipulations, open POA&M items, and SLCM execution.
- Work with PMs and cognizant Technical Authorities to ensure that all qualifying software applications in their portfolio are using the Rapid Assess and Incorporate for Software Engineering (RAISE) outlined in Section 3.5 by default for incorporating new software applications into existing authorization boundaries via certified pipelines

- Schedule ad hoc checkpoints either at the program's request or at their own determination to support RMF submissions and ensuring minutes are compiled and uploaded to eMASS to document actions/historical data.
- When optional Step 2 and Step 5 checkpoints are held, ensure minutes are compiled and uploaded to the eMASS Collaboration Board.
- Utilize the Collaboration Board in the eMASS workflow for all formal coordination during the RMF process. Detailed findings will be posted in the Artifacts tab (if necessary).

2.3.7. Program Manager / System Owner (PM/SO)

The term Program Manager / System Owner (PM/SO) as used throughout this document is synonymous with System Manager (SM) and may correlate to mission owners, as used within references (a) and (c). The PM and SO share the responsibility and authority to accomplish funded and allocated program- or system-objectives for development, production, acquisition, and sustainment to meet Navy operational needs.

The PM's and SO's responsibilities are to:

- Identify the team of RMF personnel and designate them in eMASS
- Plan, coordinate, and fund the selection of NQVs
- Ensure that RMF activities are planned and resourced for continued cybersecurity sustainment throughout the lifecycle of assigned systems. Planning and resourcing should account for administrative processing times associated with system authorization and maintenance.
- Submit system categorization recommendation to PSO
- Coordinate system security requirements, including inheritance agreements, with receiving and providing organizations or their representatives early and throughout system development
- Implement RMF cybersecurity requirements, to include security controls, for assigned systems
- Ensure POA&M development, tracking, maintenance (to ensure alignment with current programmatic schedules), and, where applicable, resolution
- Assign resources, milestones, and estimated completion dates to the POA&M for all findings marked for resolution. In the event that resolution of a finding is not planned clearly identify that in the POA&M.
- Assist with development, maintenance, and tracking of all RMF documentation
- Direct disconnection of system's interface(s) to hosted or interconnected systems with no ATO or under a DATO
- Maintain compliance with all released cyber directives to include, but not limited to: Operation Orders (OPORD), Computer Tasking Orders (CTO), Information Assurance Vulnerability Alerts (IAVA), Information Assurance Vulnerability Bulletins (IAVB), and Information Assurance Technical Advisories
- Respond to information requests during DoD and Navy cyber inspections and ensure identified findings are addressed
- Manage the overall system risk to ensure it does not rise beyond the level accepted by the AO in the authorization or, in the case of the Assess Only construct, it does not rise beyond the risk level of the initial assessment

- Assign the ISSM for the system. Program ISSMs perform RMF functions on behalf of the PM and should not be confused with command ISSMs (C-ISSM) defined in references (c) and (i). Consult local SOPs for specific terms used in your AOR
- Ensure that all qualifying software applications in their portfolio are using RAISE outlined in Section 3.5 by default for incorporating new software applications into existing authorization boundaries
- Utilize the Collaboration Board in the eMASS workflow for all formal coordination during the RMF process. Detailed findings will be posted in the Artifacts tab (if necessary)
- In coordination with the PSO ensure communication with the cognizant AO throughout the system lifecycle
- Provide and sustain vulnerability scanning guidance on how scanning is conducted for all assets in operation and upload into eMASS

2.3.8. User Representative (UR)

The UR is responsible for representing the user community of the system being authorized (e.g. the Fleet), to ensure that operational and functional requirements are met without compromising security. The UR provides input regarding the effect the implementation of the security controls has on the user community.

The UR's responsibilities are to:

- Provide input to security control tailoring
- Support development of the SP
- Provide the potential mission impact of identified vulnerabilities
- Provide input to system categorization including assisting with identifying information types and assessing provisional impact levels
- Utilize the Collaboration Board in the eMASS workflow for all formal coordination during the RMF process. Detailed findings will be posted in the Artifacts tab (if necessary).

2.3.9. Information System Security Engineer (ISSE)

The ISSE is responsible for developing and maintaining the cybersecurity architecture of a program, organization, system, or enclave, and is accountable to the PM/SO.

The ISSE's responsibilities are to:

- Oversee the development and maintenance of a system's cybersecurity solutions
- Identify AO and SCA cognizance of the system as well as any specific authorization requirements such as reciprocity, cross domain, and applicable overlays to support System Categorization
- Identify and tailor the security control baseline with applicable overlays
- Assist with development, maintenance, and tracking of the SP
- Lead the security control implementation and testing efforts
- Perform vulnerability-level risk assessment on the POA&M/CAP
- Ensure the execution of any security testing required as part of A&A or annual reviews
- Ensure the mitigation and closure of open vulnerabilities under the system's change control process

- Oversee cybersecurity testing to assess security controls and recording security control compliance status during the continuous monitoring phase of the lifecycle
- Ensure data entered into the eMASS record and POA&M is consistent with implementation results
- Utilize the Collaboration Board in the eMASS workflow for all formal coordination during the RMF process. Detailed findings will be posted in the Artifacts tab (if necessary).
- Document and provide all requested rework to the PSO/Program Management Office (PMO) for review.
- Participate in the system engineering process to ensure the systems security and cybersecurity requirements, design and testing are properly addressed throughout the system lifecycle.

2.3.10. Information System Security Manager/Officer (ISSM/ISSO)

The ISSM/ISSO is responsible for the cybersecurity of a program, organization, system, or enclave, and is accountable to the system PM/SO. Often the ISSM/ISSO will delegate execution of tasks during A&A, however accountability remains with the ISSM/ISSO. During sustainment, the ISSM/ISSO will be solely responsible and report to the PM/SO. An ISSM/ISSO may act as a Validator or SCA Liaison so long as they never execute both roles in any capacity on the same system.

Throughout the remainder of this guide this role is solely referred to as the ISSM. All responsibilities below can be delegated to the appropriate role by the program team.

The ISSM's responsibilities are to:

- Lead cybersecurity processes and activities (to include RMF) for assigned programs, organizations, systems, or enclaves
- Maintain and report system's A&A status and events to the PM/SO, PSO, SCA and AO.
- Manage the SP for assigned systems throughout their lifecycle
- Ensure the execution of annual security reviews, annual testing of security controls, and annual testing of the contingency plan, in line with FISMA requirements
- Manage POA&M entries and ensuring vulnerabilities are properly tracked, mitigated, and resolved where possible.
- Assist with identification of the security control baseline set and any applicable overlays
- Coordinate the validation of security controls with the PM/SO, NQV, SCA Liaison, PSO, and AO CSA
- Assemble the Security Authorization Package and submit for adjudication
- Register and maintain the system in eMASS
- Assess the quality of security control implementation against all requirements in accordance with the approved SLCM strategy
- Plan and perform cybersecurity testing to assess security controls and recording security control compliance status during sustainment
- Report changes in the security posture of systems to the AO
- Utilize the Collaboration Board in eMASS workflow for all formal coordination during the RMF process. Detailed findings will be posted in the Artifacts tab (if necessary).
- Track assessed and validated vulnerabilities via an RMF system POA&M, and ensure they are properly rated and ranked during system Configuration Control Boards (CCBs) to capture the most critical vulnerabilities that require correction
- Ensure the execution of all Continuous Monitoring related requirements as defined in the SLCM
- Review all data produced by Continuous Monitoring activities, update the eMASS record as necessary, and escalate to leadership for action, if required
- Correlate findings from non-RMF vulnerability assessments (e.g., Development Test (DT)/Operational Test (OT), penetration testing, Command Cyber Operational Readiness Inspection (CCORI), etc.) to RMF controls for tracking, ensuring a holistic risk assessment

When circumstances warrant, a single individual may fulfill both the ISSM and the ISSO roles. The role of the ISSO is to:

- Assist the ISSMs in executing their duties and responsibilities
- Ensure compliance with all Navy, DON, and DoD cybersecurity policies
- Verify all users possess the requisite security clearances and awareness of their responsibilities for systems under their purview prior to being granted access
- Ensure plans and channels are in place for incident response, business continuity, disaster recovery, and vulnerability and threat reporting and that team members are trained accordingly
- Ensure relevant policy and procedural documentation is current and accessible to properly authorized individuals
- Utilize the Collaboration Board in the eMASS workflow for all formal coordination during the RMF process. Detailed findings will be posted in the Artifacts tab (if necessary).

Section 3: Authorization Methods

All Navy systems must be authorized or assessed using the methods outlined below. The corresponding definitions and determination criteria and how it applies to a system can be found in Appendix G of this guide.

3.1. Authorization Categories

- See Appendix G, Authorization Options Guide

3.2. Assess Only Categories

- The Assess Only construct is implementable at the discretion of the cognizant AO and is divided into two major categories: Assess and Approve; and Assess and Incorporate.
- Assess and Approve. This construct is designed for systems that do not merit a full authorization, and will not be incorporated into an existing authorization boundary. Guidance for the Assess and Approve process will be published by the AOs.
 - This construct is typically used for approving single purpose IT devices (e.g., noise canceling headsets, GPS devices) or IT services for use.
- Assess and Incorporate. This construct is designed for systems that do not merit a full authorization, but will be incorporated into an existing authorization boundary. Guidance for the Assess and Incorporate process will be published by the AOs.
 - This construct is typically used for incorporating hardware or applications into existing authorization boundaries, however it can also be leveraged by enclaves to incorporate sub-systems into a single enclave authorization boundary.
 - The Rapid Assess and Incorporate Software Engineering (RAISE) process leverages this construct and can be used for all applications that utilize a designated RAISE Platform of Choice (see section 3.5).

3.3. Reciprocity

Cybersecurity reciprocity (hereinafter referred to as “reciprocity”) is defined in CNSSI 4009 as the mutual agreement among participating enterprises to accept each other’s assessments in order to reuse IS resources and/or to accept each other’s assessed security posture in order to share information resources and/or documentation. Applied appropriately, reciprocity enhances cybersecurity through consistent application of controls across multiple enclaves while reducing redundant testing, assessment and documentation, and the associated costs in time and resources.

In accordance to the reciprocity memo (ad), to the greatest extent possible, AOs will accept the information in a Security Authorization Package, and authorization decision generated by another federal agency or DoD Component (referred to in this guide as the “owning organization”). The AO will consider the risk implications of the owning organization’s Security Authorization Package on the particular Navy environment and subsequently make an authorization decision. Each AO has designated reciprocity users within eMASS who are able to view artifacts from other components or services. Components will maximize reuse of assessment and authorization Body of Evidence (BOE) developed for prior system authorization and deployments within sister DoD Components. Any such cybersecurity assessment, authorization and testing conducted by another component shall be evaluated before additional assessment or testing is undertaken. Assessments, authorizations, and tests by another DoD Component shall be presumed to have been correctly completed, and that assessment, authorization and testing, and the resultant test evidence, will be accepted by all DoD components as a basis for Assessment and Authorization.

Regarding those instances where major applications are deployed to enclaves that do not take ownership of the system, the USN RMF Portal pages Enterprise Reciprocity and Non-Enterprise Reciprocity already make it clear that acceptance of the deployed system requires the production of an MOA, MOU, Interconnections Security Agreement (ISA), etc., along with updating of its enclave documentation.

In the case where an AO declines to reciprocate risk from another DoD Service, that AO must provide, via formal correspondence, their rationale for that decision to DDSISO(N) within 7 days.

Requests for documentation not included in the deploying component’s RMF package must be endorsed by the requesting Service CISO before being forwarded to the deploying AO.

3.4. Authorization with Special Considerations

While the majority of A&A efforts for the Navy will be associated with systems, there are multiple alternate situations that will require additional considerations during the RMF effort. This section discusses areas requiring special consideration as described in Table 2 - Special System Considerations and Guidance.

Table 2. Special System Considerations and Guidance

System Type	Description	Navy Authorization Guidance
Systems implementing a cross-domain solution (CDS)	Although the AO responsible for the system does not certify the CDS, the AO must consider the security impact of the CDS operation in the overall authorization decision. The higher classification network of a CDS is referred to as the high side. In addition to the higher-side security requirements, the security requirements for the integrity of the information transfer must be considered and implemented on the connecting lower-side system.	• Include the CDS device and the CDS ticket number(s) on the topology diagram for the system with the higher classification of the cross domain connection, and include the CDS Overlay in the Security Control Baseline. The CDS ticket numbers must also be identified in the System Information section within eMASS. PM/SO/ISSE must confirm if the CDS is within the system's authorization boundary or external to the boundary if it belongs to a separate entity. In either case it must be displayed on the appropriate topology diagram. Engage with the Navy CDS Office (NCDSO) to coordinate CDS processing.
Systems providing Unified Capabilities (UC)	Reference (k) contains policy for UC, and describes the process for the Information Assurance (IA) certification of UC products.	• Include UC products inside the authorization boundary of host system • Provide the UC product IA certification documentation to support the overall system A&A
Government Owned Contractor Operated (GOCO)	GOCO systems are DoD-owned systems operated by a contractor or other entity on behalf of the DoD. Externally operated systems that are dedicated to DoD processing and are effectively under DoD configuration control must be authorized as DoD systems.	• Authorized by Cognizant AO
DoD partnered systems	DoD partnered systems are systems that are developed jointly by DoD and non-DoD mission partners, comprise DoD and non-DoD ISs, or contain a mix of DoD and non-DoD information consumers and producers, (e.g., jointly developed systems, multi-national or coalition environments, or first responder environments).	• Clearly define security control selection, system authorization, and other risk management responsibilities via a formal partnership agreement (e.g., a Memorandum of Understanding/Agreement (MOU/MOA), or Service Level Agreement (SLA)) • Identify AO and authorize prior to Navy use of the capability • Identify lead executing agency and AO
Commercially-Owned, Commercially-Operated (COCO)	Per reference (l): Non-DoD IT to store, process, transmit DON data, to include data of sensitive nature (PII).	• Contact AO office to determine requirements • Meets minimal standards specified by reference (l) • COCO may require AO authorization as required by separate DoD/Navy policy or instruction.

3.5. Rapid Assess and Incorporate Software Engineering (RAISE)

The RAISE process incorporates Agile and DevSecOps principles to streamline and accelerate the RMF process using automation, cyber verification tools, and certified Continuous Integration/Continuous Delivery (CI/CD) pipelines to ensure containerized software applications are built, tested, and deployed securely.

Using RAISE, software applications will be assessed and incorporated into an existing RAISE Platform of Choice (RPOC) Authority to Operate (ATO) and are not required to have a separate ATO.

A RAISE 2.0 Implementation Guide is posted to the USN RMF portal for detailed implementation instructions.

Section 4: The Navy RMF Process

This section describes each step of the Navy's implementation of RMF, along with a snapshot of the organization's Responsible, Accountable, Supporting, and Consulted (RASC) for each step depicted in a RASC chart. Detailed descriptions follow these charts and should be used as the primary source for the Navy's process.

The RMF process aligns with the DoD Acquisition milestones from the DoD Program Manager's Guidance for Integrating the Cybersecurity RMF into Systems Engineering Life Cycle.

4.1. RMF Step 1 - Categorize System

System categorization should be completed during the initial development of a system. Categorization, and subsequently, a system's security control baseline, will establish the secure system architecture requirements when it is easiest and least expensive to implement.

System categorization is based on mission functions and intended operational environment (e.g., ship, cloud, aloft, headquarters building, etc). In accordance with reference (e), system security categorization will determine potential impact values for the information types received, processed, stored, displayed, or transmitted by the system and will identify overlays relevant to the system and its operating environment. If categorization cannot be supported by an inheritance model, categorization of systems that are closely coupled to specific mission and same environments (ex: NC3) can re-use categorization information across the identified system candidates to meet Step 1 categorization.

Categorization is required for all new systems. Systems with existing authorization may also require re-categorization at the discretion of the PSO if the system baseline has changed due to new information types, technology, functions or capabilities being implemented. This section of the guide defines system categorization, describes how to categorize a system, and specifies the roles and responsibilities of required personnel in the process.

RMF Step 1 begins with the PM/SO forming an RMF team of qualified personnel. The ISSM registers the system in eMASS and should refer to eMASS user guides for detailed instructions.

Table 3. RASC - Categorize System

	Task Description <i>What is the action?</i>	Responsible <i>Who is actually doing the work?</i>	Accountable <i>Who gets in trouble when something goes wrong?</i>	Supporting <i>Who can the responsible party direct to help?</i>	Consultable <i>Who should the responsible party ask for advice?</i>
1.1	Identify and appoint the initial RMF personnel for the system (this can change throughout the system lifecycle based on personnel turnover/availability)	PM / SO	PM / SO	---	PSO
1.2	Register the system in eMASS	ISSM	ISSM	ISSE	---
1.3	After registration of the system has been approved, complete the categorization within eMASS.	ISSE, ISSM	PM / SO	IO	PSO

1.4	Approve categorization	PSO	PSO	PM / SO	AO CSA
1.5	Initiate the Security Plan (SP) in eMASS	ISSE	PM / SO	---	ISSM, NQV, PSO

The SP will be updated throughout the RMF process (see appendix B for details).

To facilitate Security Authorization Package development, it is important to engage the designated AO CSA and SCA Liaison throughout the RMF process.

4.1.1. Inputs, Outputs, and Required Tools

Table 4. Step 1 Inputs, Outputs, and Required Tools

Input	Output	Tool Required
1.1 RMF Team Information	1.6 Categorization <i>PSO Approval is Required to Progress</i>	eMASS (https://navy.emass.apps.mil) ;
1.2 System Concept of Operations	1.9 Initial Security Plan	
1.3 System Information Types ²		
1.4 System Mission Information		
1.5 National Security System Determination Questionnaire		
1.6 Categorization		
1.7 System Design Documentation		
1.8 Planned System Architecture		eMASS (https://navy.emass.apps.mil) ;
1.9 Security Plan	1.10 System Type Designation	eMASS; DITPR-DON
	1.11 DITPR-DON Record (if applicable)	
	1.12 eMASS Record	

4.1.2. Establish an Effective Workforce

The PM/SO must ensure assigned personnel are qualified per references (f) through (i) and are free from conflicts of interest. For example, the AO or SCA cannot be, or report to, the PM/SO or Program Executive Office (PEO); nor can the UR be or report to the PM/SO; nor can the ISSM be the SCA-L. These examples are not an exhaustive list of potential conflicts.

RMF practitioners must have access to appropriate systems and forms to document the results of RMF Step 1 (Categorization). To complete the documentation of categorization decisions, access is required to eMASS and to DADMS, which includes DITPR-DON. PSO eMASS system administrators can provide appropriate access.

4.1.3. Complete System Categorization

The categorization process is the same for all Navy IT Types.

4.1.3.1. Document Information Types Processed

Within eMASS, identify and record all the types of information received, processed, stored, displayed, or transmitted by the system. An information type is a specific category of information (e.g., privacy, medical, proprietary, financial, investigative, contractor-sensitive, security management, etc.) defined by an organization, public law, executive order, directive, policy, or regulation. Information types shall be identified based on NIST SP 800-60 Vol II, "Guide for Mapping Types of Information and Information Systems to Security Categories" and the DON Information Types Baseline located in eMASS.

4.1.3.2. Select Provisional Impact Values (if using known information types)

eMASS automatically provides provisional impact levels of low, moderate, or high associated with each information types for each of their respective confidentiality, integrity, and availability breaches. This process ultimately outputs a system's initial security control baseline by determining what level of protection is required to appropriately protect the confidentiality, integrity, and availability of the information that system stores and processes. The process of determining the impact values is based on reference (d), using the terms defined in reference (e).

The impact values of **low**, **moderate**, or **high** are assigned based upon the anticipated magnitude of harm that can be expected to result from the consequences of unauthorized disclosure of information (Confidentiality), unauthorized modification of information (Integrity), unauthorized destruction of information, the loss of information, or information system availability (Availability). Additionally, any other factors that may affect the impact value are also taken into consideration when assigning the final values for the system. Table 5 - Impact Values summarizes the potential impact definitions for each security objective based on reference (e).

The definitions of **limited**, **serious**, and **severe or catastrophic** can be found in reference (e).

4.1.3.3. Document Operational Impact and Additional Considerations

The ISSE, ISSM, UR, and PM document the system's operational requirements with support of the PSO and note any other additional considerations. The PM/SO and ISSM will adjust the information types' impact levels based on this information. If the system is identified as processing Controlled Unclassified Information (CUI) and above per the NIST SP 800-171 the minimum mandatory baseline is Moderate Confidentiality and Moderate Integrity.

Table 5. Impact Values
POTENTIAL IMPACT³

³ Amplification for each impact definition, as well as examples for each, can be found in FIPS 199 (reference (e)).

Security Objective	LOW	MODERATE	HIGH
Confidentiality Preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information. [44 U.S.C., SEC. 3542]	The unauthorized disclosure of information could be expected to have a limited adverse effect on organizational operations, organizational assets, or individuals.	The unauthorized disclosure of information could be expected to have a serious adverse effect on organizational operations, organizational assets, or individuals.	The unauthorized disclosure of information could be expected to have a severe or catastrophic adverse effect on organizational operations, organizational assets, or individuals.
Integrity Guarding against improper information modification or destruction, and includes ensuring information non-repudiation and authenticity. [44 U.S.C., SEC. 3542]	The unauthorized modification or destruction of information could be expected to have a limited adverse effect on organizational operations, organizational assets, or individuals.	The unauthorized modification or destruction of information could be expected to have a serious adverse effect on organizational operations, organizational assets, or individuals.	The unauthorized modification or destruction of information could be expected to have a severe or catastrophic adverse effect on organizational operations, organizational assets, or individuals.
Availability Ensuring timely and reliable access to and use of information. [44 U.S.C., SEC. 3542]	The disruption of access to or use of information or an information system could be expected to have a limited adverse effect on organizational operations, organizational assets, or individuals.	The disruption of access to or use of information or an information system could be expected to have a serious adverse effect on organizational operations, organizational assets, or individuals.	The disruption of access to or use of information or an information system could be expected to have a severe or catastrophic adverse effect on organizational operations, organizational assets, or individuals.

4.1.3.4. Integrity of the Final System Category

While impact levels for individual information types may be modified in the context of their mission, the automatically calculated high watermarked system-level impact values must not be altered. The system category is the primary input into the security control baseline, which may be tailored.

4.1.4. Receive RMF Step 1 Approval

The PSO approves the system categorization prior to moving forward with Security Control Selection. eMASS will use the system's categorization information to generate the initial baseline set of controls in RMF Step 2.

4.2. RMF Step 2 - Select Security Controls

Security controls are the management, operational, and technical safeguards or countermeasures prescribed for an information system to protect the confidentiality, integrity, and availability of the system and its information.

It is the responsibility of the ISSE and PM/SO to consider control inheritance and inheritance models when assigning controls in the security control selection process. Navy inheritance models can be leveraged during security control inheritance review and assignment and can be found on the USN RMF Portal. The remaining set of controls will be considered allocated cybersecurity requirements.

Programs and reviewers are responsible for leveraging the RMF Step 2 SOP (posted to the USN RMF portal) to ensure package quality and consistency.

Table 6. RASC - Select Security Controls and SLCM Strategy

	Task Description <i>What is the action?</i>	Responsible <i>Who is actually doing the work?</i>	Accountable <i>Who gets in trouble when something goes wrong?</i>	Supporting <i>Who can the responsible party direct to help?</i>	Consultable <i>Who should the responsible party ask for advice?</i>
2.1	Tailor the system's security controls and identify any Common Controls and overlays based on the output of RMF Step 1 System Categorization	ISSE	PM / SO	ISSM	PSO, AO CSA, SCA Liaison, UR
2.2	Identify and justify any controls output from Categorization that are Not Applicable (N/A) in eMASS by reviewing all individual assessment procedures and their implementation guidance for applicability. This will initiate the POA&M within eMASS, entering the N/A justification within the assessment procedure's test results. If the entire control is N/A, then mark as such in the Control Dashboard and enter a high-level N/A justification in the field provided.	ISSM	PM / SO	ISSE	PSO, AO CSA, SCA Liaison, UR
2.3	If possible, determine applicability of Ports, Protocols, and Services Management (PPSM) <i>PPSM Registration must be completed prior to RMF Step 5 but can be done during RMF Step 2 to prevent delay in authorization.</i>	PM/SO	PM/SO	ISSE, ISSM	PSO
2.4	Develop the initial System Level Continuous Monitoring Strategy	PM / SO, ISSM	PM / SO	ISSE	PSO, AO CSA
2.5	Review SP	PSO	PM / SO	---	AO CSA, SCA Liaison

2.6	(Optional) Coordinate and complete the RMF Step 2 Checkpoint. This is a collaborative review of the SP and SLCM. <i>This is a collaborative review of the SP and SLCM</i>	PM / SO, PSO, AO, SCA	PSO	ISSE, ISSM, SCA Liaison, AO CSA	---
2.7	Step 2 Approval. As part of this AO will review the categorization.	AO	---	ISSE, ISSM, SCA Liaison, AO CSA	---

4.2.1. Basic Considerations

The outcome of RMF Step 1 will determine the subset of that catalog's controls that initially apply to a system prior to tailoring specific controls of the baseline.

In addition to tailoring the initial control set and overlays, common and inheritable controls must be identified. Consulting the AO CSA and engineering early reduces rework later.

The System Categorization, initial SP and initial SLCM Strategy are presented at the optional RMF Step 2 Checkpoint where they are reviewed by the AO CSA. The ISSM in coordination with the PSO ensures that appropriately knowledgeable representatives are involved in the approval process, as failure to do so may result in delays. During this process the required parties endorse the system by moving it to the next step in the eMASS workflow; or the deficient artifact is sent back to the originator for rework.

Step 2 Note: In the event that your system requires an OPNAV Assured Compliance Assessment Solution (ACAS) scanning waiver, it is recommended that you obtain approval for the waiver during Step 2 in accordance with NAVADMIN 097/19, "Navy Scanning Policy." This exception should be documented in the SAP with alternative means to assess appropriate devices for potential vulnerabilities.

Table 7. Inputs, Outputs, and Required Tools of RMF Step 2

Input	Output	Tool Required
1.6 Categorization	2.1 Initial Control Set	<u>eMASS;</u> <u>DoD RMF KS Security Controls</u>
1.9 Security Plan		
1.12 eMASS Record		
2.1 Initial Control Set	2.6 Updated SP	<u>eMASS</u> <u>DoD RMF KS Security Control Explorer</u>
2.2 Control Tailoring Analysis		
2.3 Inheritance Documentation (MOAs, MOUs, etc.)		
2.4 Control Selection Form or eMASS Control Selection Module		
2.5 Assertion of PPSM Applicability		
2.6 Updated SP	2.8 Step 2 Checkpoint (Optional)	---
2.7 Initial SLCM Strategy		

1.6 Categorization		
2.8 Step 2 Checkpoint (Optional)	2.9 Step 2 eMASS Concurrence Workflow <i>Required to Progress to Step 3</i>	eMASS
	2.10 Approved SP	

4.2.2. Security Control Baseline

All DoD systems will be treated as National Security Systems (NSS) for the purposes of establishing a CNSSI 1253 security control baseline as a common reference point. While reference (d) is written specifically for information systems that process, store, or transmit National Security Information (NSI), the DoD has adopted its process for selecting controls among all DoD systems, regardless of NSS designation. Utilizing reference (o) as the source catalog, the Navy will use the baseline security categorization method.

When establishing the overall security category of Navy IT, the values determined for confidentiality, integrity, and availability are retained. Retaining the discrete values for each of the three security objectives is done to provide a better granularity in allocating security controls to baselines.

In order to ensure due diligence is exercised in tailoring controls, justification must be provided when marking controls as not applicable (N/A). Many controls and enhancements added as a result of the NSS control baseline may also be required by DoD policy for all DoD systems regardless of whether or not they are NSS. Non-NSS systems cannot set a Security Control as not applicable based solely on that Security Control being part of the NSS baseline. Justification is required to tailor that Security Control from the Security Control set. Ultimately, the AO determines the sufficiency of justification pertaining to all other control tailoring.

Note: For systems which are inheriting controls and protections from other eMASS records (e.g., Tier I/II inheritance, hosting platforms, etc), the inherited controls should be included in the control baseline and inheritance agreements should be codified during Step 3.

4.2.3. Overlays

Security control overlays are specialized sets of controls tailored for specific types of missions/business functions, technologies, or environments. Overlays are used to make adjustments to the CNSSI 1253 baseline. Each overlay is a complete set of security controls, control enhancements, and supplemental guidance derived from the application of tailoring guidance found in reference (o).⁴ Organizations apply security control overlays by using the guidance in each of the standardized, approved, and CNSSI-published overlays. DON-specific overlays are available on the [USN RMF Portal](#).

Overlays are identified and applied after the general security baseline is established. If more than one overlay applies to a system, any potential conflicts that may arise between overlay specifications and baseline controls must be captured in eMASS when completing the control selection and management tab.

4.2.4. Tailoring Security Controls

Programs tailor security controls and assessment procedures to determine the applicability of baseline security controls and to add additional security controls to ensure alignment with organizational and mission environments using references (d) and (o). The tailoring process includes:

- Identifying common controls in initial security control baselines
- Selecting applicable compensating security controls
- Assigning specific values to organization-defined security control parameters with explicit assignment and selection statements
- Ensuring all controls associated with the appropriate Security Requirements Guides (SRG) and Security Technical Implementation Guides (STIG) are included within the tailored baseline and identified through the utilization feature in eMASS
- Providing any necessary details for control implementation

All tailoring decisions, including the specific rationale for those decisions, must be documented for each security control in eMASS. The SP must document and justify any security controls from the initial security control set that will not be implemented in the system, and for which no compensating controls will be substituted. These controls will be marked Non-Compliant (NC) during testing and not tailored out as N/A. Ultimately, justifications must satisfy the cognizant AO.

4.2.5. Identify Common Controls

Common security controls are inherited from one or more organizational information systems, physical sites (e.g., ashore, afloat, and mobile hosting environments or platforms), and governing policies. A Common Control Provider (CCP) is an entity responsible for the implementation, assessing, and monitoring of common controls. CCPs will first be identified at the DoD level (Level 1; [DoD RMF KS](#)), Navy level (Level 2; [USN RMF Portal](#)), and enclave level (Level 3), in accordance with reference (p). Level 3 common controls are maintained locally by the Level 3 CCPs (i.e., information systems providing common controls for inheritance) as an authorized package in eMASS. Controls may be hybrid, meaning a security control that is implemented in an information system in part as a common control and part as a system-specific control. Table 8 defines each governance level and the common control sources for inheritance. Systems may not be able to accept inheritance for all Level 1, Level 2, and Level 3 controls if they are not compliant with the associated higher level policies. All CCPs must identify their common controls in accordance with the instructions in the eMASS User Guide. It is the responsibility of program offices to periodically visit the USN RMF Portal and DoD RMF KS for updated inheritance information.

Table 8. Common Control Sources

Governance		Common Control Source
Tier 1: Organization	DoD Level	DoD CIO, ISRMC, DSAWG, DoD SISO, DoD Cybersecurity Architecture, RMF TAG, KS
Tier 2: Mission/Business Process	DoD Component Level	PAO, DON SISO (DON CIO), DDSISO (N2/N6)

Tier 3: Common Control Provider	Enclave Level ⁵	Common control providers (e.g., ECH II policies, system cybersecurity program, enclave owners, etc.)
---------------------------------	----------------------------	--

Identifying Tier 1 Common Controls: Obtain the current list of DoD-level common security controls published on the [DoD RMF KS](#). Document these common controls as "Inherited" in the "Implementation Status" field and "Common" in the "Security Control Designation" field of the Implementation Plan in eMASS. Request inheritance from CCPs through eMASS.

The DoD CIO identifies common security controls that are satisfied by existing DoD policy and guidance and are applicable throughout the DoD. Navy systems are automatically compliant with Tier 1 common security controls which will be automatically applied/satisfied in eMASS.

Identifying Tier 2 Common Controls: Obtain the current list of Navy Enterprise common security controls published on the [USN RMF Portal](#). Document these common controls as inherited controls in the system's SP and annotate as such in eMASS by marking them as "Inherited" in the "Implementation Status" field and "Common" in the "Security Control Designation" field of the Implementation Plan in eMASS..

DON SISO and DDSISO (N) identify Navy-specific common security controls that are satisfied by existing Navy policy and guidance and are applicable throughout the Navy. Navy systems are automatically compliant with Tier 2 common security controls by implementing existing Navy policies and guidance. Tier 1 and Tier 2 common security controls have been identified by Defense Information Service Agency (DISA) and DON respectively. Applicable Tier 1 and Tier 2 controls are selected and inherited in accordance with the CS TA Navy Enterprise Inheritance Guide and the Navy Enterprise Inheritance Control Correlation Identifier (CCI) Selector Catalog. This information will be published on the [USN RMF Portal](#) and incorporated into eMASS as required as new inheritable controls are identified.

Identifying Tier 3 Common Controls: Obtain the current list of Tier 3-specific common security controls from the Common Control Provider (if applicable) and establish an inheritance agreement through eMASS or a written inheritance agreement (e.g., MOA) for the inherited common controls external to eMASS. Request inheritance through eMASS for Common Control Providers in eMASS. Document these common controls as "Inherited" (or "Manually Inherited") in the "Implementation Status" field and "Common" in the "Security Control Designation" field of the Implementation Plan in eMASS. "Manually Inherited" will be selected for systems inheriting from hosting sites/facilities/agencies that are not available in eMASS and records where Systems' Owners only provide inheritance through written agreements (e.g., MOA). The implementation guidance for Common Control Providers is being developed. In the interim, Common Control Providers should reference the [USN RMF Portal](#) and work with the AO to determine a way forward.

Tier 3 Common Controls are derived from authorized eMASS packages designated as Tier 3 common controls. Document these common controls as inherited controls in the system's SP

and request inheritance in eMASS. In some cases Tier 3 manual inheritance may be required, in which case the ISSM shall ensure appropriate MOAs or similar formal agreements are on file in support of Tier 3 common inheritance. Validating the integrity of the multiple echelons a system may receive Tier 3 common controls from requires due diligence when developing a system's security control list.

An example of a Tier 3 common control package is physical security of a site such as a base. The base provides common security for all tenants and those applicable controls can be inherited through those common controls.

When Tier 1 and 2 Common Controls are published, they may affect the Tier 3 controls and stipulations, and all Tier 3 systems providing common controls must review those controls whenever an upper tier control is published in case of an impact.

4.2.5.1. Providing Common/Inheritable Controls

For systems providing inheritable controls through eMASS, identification of those controls that can be inherited must be done during security control selection in RMF Step 2 and manually marked as such in eMASS in order for an inheriting system to use them.

Enclaves may identify enclave-specific inheritable security controls made available to systems that are nested within the enclave through agreements between the enclave and the nested systems. Risks introduced via inheritable security controls at the enclave level must be documented and either accepted, mitigated, or rejected by the AO. Current lists of enclave-level inheritable security controls are maintained locally by the hosting enclaves.

4.2.6. Scoping Considerations

Scoping considerations allow programs to build a more detailed foundation to make risk-based decisions about the security control baseline. Determining the appropriate level of protection is based on mission/business functions, the operating environment, and the sensitivity of the information. An intensive review of scoping considerations can be found in reference (o). While operational functionality is a factor in the tailoring process, inability to meet the security control due to existing system architecture or funding does not justify for removal of a control from the baseline.

- Control Allocation and Placement Considerations – This consideration is making a risk-based decision about where to apply or allocate specific security controls in systems in order to achieve needed capability and to satisfy security requirements.
- Operational/Environmental-Related Considerations – Some of the security controls in the baseline assume the existence of certain operational or environmental factors. If these factors are absent or significantly different from those assumptions, these considerations can be used to tailor the system's baseline. Common operational and environmental factors include but are not limited to:
 - Mobility of the physical hosting environment
 - Systems designed to operate as single-user systems or operations
 - Non-networked systems or systems with limited or sporadic bandwidth

- Systems or system components with limited functionality (such as fax machines or scanners) to execute code
- Non-persistence of information or systems
- Approved public access
- Technology-Related Considerations – Technology-Related Considerations – Security controls that provide protection to specific technologies (e.g., Voice-Over-IP (VOIP), wireless, or mobile code) that are not present in the baseline need to be added to the security control set. These security controls may be marked N/A if those technologies are not used or required to be used on the system. However, some controls address the presence of a policy or restrictions (e.g. AC-18 (a) (CCI-001438) that must be applied.
- Mission Requirements-Related Considerations – Security controls that have the potential to degrade, debilitate, or otherwise hamper critical missions and/or business functions when implemented will be marked as NC during step 3 using a risk based methodology as the justification. These controls remain on the security control baseline and must provide a justification or rationale, stating why they cannot be implemented. Controls marked as non-compliant must be documented in the POA&M and risk can be accepted by the AO via eMASS.

4.2.7. Compensating Controls

After initial application of scoping considerations, compensating controls can be selected for a system. Compensating controls act as alternative controls in lieu of certain baseline controls. They must provide comparable protection for the system and its information. Compensating controls are used when systems are unable to support baseline controls due to the environment of the system, or being cost prohibitive.

Compensating controls are selected in the following sequence:

1. Select compensating controls from reference (o). If appropriate compensating controls are not available, the ISSE may adopt suitable compensating controls from other sources.
2. Articulate how compensating controls provide equivalent security capabilities for their system and why the baseline security controls could not be employed.
3. The PM/SO and ISSE assess the programmatic risk associated with implementing compensating controls in their system.

4.2.8. Supplementing Security Control Baselines

Programs can add supplemental controls to further tailor a system's baseline control set as required. Any controls added as part of this supplementation must provide a rationale for its inclusion in the baseline.

Control enhancements can also be added to the baseline. Control enhancements are included with many security controls and are also listed in the reference (o) baseline. Enhancements are selected in order to increase the strength of the base control and are intended to be implemented only in conjunction with implementation of the base control.

Some of the most common reasons for supplementing and enhancing controls are:

- Advanced Persistent Threats to a system
- Cross-domain interfaces
- Mobility

- Supply Chain
- Operational Technology

4.2.9. Additional Specification Information for Control Implementation

Security controls may lack the detail required to understand their intent. Thus, the ISSE may provide refinement of implementation details, specification requirement, or apply the control differently. The intent of the security control cannot be changed during this process. Refinement can be provided directly in eMASS either in the security control's notes or as an artifact.

4.2.10. AO CSA Concurrence on Tailored Security Control Baseline

Once the security controls have been tailored and documented, the AO CSA or AO will review control selection. Changes to the tailored baseline after AO CSA Concurrence are approved at RMF Step 5.

4.2.11. Develop SLCM Strategy

The program develops the initial SLCM Strategy for the system per reference (b). The SLCM Strategy must address all of the controls documented in the SP. Appendix F of this guide discusses the SLCM Strategy in detail.

4.2.12. (Optional) RMF Step 2 Checkpoint

The RMF Step 2 Checkpoint is optional and is the responsibility of the PSO to initiate. In all cases, the PSO is responsible for endorsing the completed SP and SLCM Strategy. If a checkpoint is deemed necessary by the PSO or program, they shall notify the AO and SCA POC's to schedule a checkpoint as described in Appendix J of this guide. As part of the optional Checkpoint they must submit both the SP and SLCM Strategy to the AO for approval. The AO, or their designated representative, approves the completed documentation to initiate RMF Step 3. Any changes to the documentation after approval will need to be resubmitted to the AO for impact consideration during RMF Step 5.

4.2.13. RMF Step 2 Approval

The AO approves the SP and SLCM Strategy through the eMASS SP Approval workflow. Appendix J discusses checkpoints in greater detail

4.3. RMF Step 3 - Implement Security Controls

RMF Step 3 is the implementation of the approved security control set. For systems that have already been developed and fielded, system owners are still responsible for assessing the implementation of the approved control set and implementing non-compliant controls where possible. The program tests its own security control implementation in preparation for the security control assessment in Step 4.

Security control implementation must be consistent with the approved SP and in alignment with the organization's enterprise architecture and information security architecture. The information security architecture is a resource to allocate security controls (i.e., security mechanisms and services) to an information system and any organization-defined subsystems.

Standards for identifying best practice security control implementation for different system types are available in the [CS TA Standards](#) which should be implemented to the greatest extent possible in accordance with references (v) and (y). There is no eMASS workflow for Step 3 however programs will continue to report compliance to the assessment procedures within eMASS.

Table 9. RASC - Implement Security Controls

	Task Description <i>What is the action?</i>	Responsible <i>Who is actually doing the work?</i>	Accountable <i>Who gets in trouble when something goes wrong?</i>	Supporting <i>Who can the responsible party direct to help?</i>	Consultable <i>Who should the responsible party ask for advice?</i>
3.1	Plan & ensure required resources are in place to implement all security controls outlined in the SP	PM / SO	PM / SO	---	ISSE, ISSM
3.2	Implement the completed and approved security control list <i>The ISSE leads the security control implementation and testing</i>	ISSE	PM / SO	ISSM,	PSO, SCA Liaison, AO CSA
3.3	Update POA&M with Non-compliant security controls as required	ISSM/ISSE	PM / SO	---	PSO
3.4	Perform preliminary testing of the security control implementation <i>This part of the security engineering loop is used to verify that the required security controls are in place. As testing occurs and issues are identified they should be fixed and retested.</i>	ISSE	PM / SO	ISSM,	PSO, SCA Liaison, AO CSA
3.5	Conduct all preliminary technical testing (STIGs, SRGs and ACAS Scans) and document findings in the POA&M.	ISSE	PM / SO	ISSM,	PSO, SCA Liaison, AO CSA
3.6	Conduct an initial complete risk assessment and document results in the POA&M	ISSE	PM / SO	ISSM,	PSO, SCA Liaison, AO CSA

4.3.1. Inputs, Outputs, and Tools Required

Table 10. Inputs, Outputs, and Required Tools of RMF Step 3

Input	Output	Tool Required
-------	--------	---------------

2.11 Approved Security Plan (SP) <i>This SP identifies the security controls that will be implemented</i>	3.1 Updated SP <i>This updated documentation is based on the final implementation of the tailored security control set.</i> 3.1 Updated POA&M.	<u>eMASS</u> <i>The ISSE uses eMASS for documenting the final security control set implementation. Implementation of security controls is an engineering process involving a host of products specific to each control, and cannot be fully covered here.</i>
--	---	--

4.3.2. Perform Preliminary Control Testing

The preliminary control testing is part of the Navy's Security Engineering Loop and should be incorporated early to align to systems engineering and development testing.⁶ To assist the ISSM in the preliminary control testing DISA provides a list of all of the applicable SRGs, STIGs, and Security Content Automation Protocol (SCAP) benchmarks on the [DoD Cyber Exchange](#). These guides and benchmarks should be downloaded for security control implementation and testing. Where possible, programs are encouraged to coordinate their initial testing with the SCA and Validator to expedite Step 4.

⁶ The initial security control test is equivalent to the testing of a system for security and functionality issues in a certification test & evaluation (CT&E) scenario. This test allows the ISSE to address any issues prior to security control assessment in Step 4. No official output is required from the AO at this step. Not all results from the preliminary security control testing should be used to develop the POA&M since the expectation is that most issues will be corrected prior to the formal security assessment. However, the POA&M should be initiated and updated at this step if a vulnerability is identified that cannot be corrected.

4.4. RMF Step 4 - Assess Security Controls

4.4.1. Security Control Assessment

The ISSE performs the security control assessment during Step 3 to verify that each security control has been properly implemented. The Validator shall execute assessment activities, conduct testing, and ensure accuracy of control status, while annotating compliance/non-compliance in eMASS. On a case-by-case basis the Validator may accept test results from Step 3. The Validator develops a list of non-compliant controls in order to understand, assess the mitigations, and document the overall risk presented by the implementation. This step is outlined in the table below. Assessment is a key activity in the RMF process and a thorough assessment requires dedicated time and personnel. Completion of the SAR requires a current approved SAP. A SAP is approved using the SAP Approval workflow. An authorization decision is received using the 'RMF Step 4+5: Assess & Authorize' or 'Risk Assessment' workflows. The legacy 'Assess and Authorize' workflow is only authorized for use in special pre-approved circumstances.

Programs and SCA are responsible for utilizing the RMF Step 4 SOP (posted to the USN RMF portal) to ensure package quality and review consistency. As part of issuing a SAR the cognizant SCA will conduct a technical assessment of the cyber risk of exploitation by leveraging the body of evidence (BOE) provided as part of an authorization package. The assessment will include an analysis of the cybersecurity solutions (i.e. allocated security controls) implemented to reduce/mitigate risk and mission impact. The minimum BOE that is required to make risk assessment includes evidence from each of the following five categories. All of these evidence categories are included in standard RMF documentation (e.g., POA&M/CAP, authorization diagram) however the below categories provide examples of alternative pieces of evidence that can be used to define them.

- (1) System technical design:
 - (a) Hardware/Software/Ports, Protocols, Services Lists
 - (b) Function of system components within the system and enclave
 - (c) Criticality of system within the enclave mission
- (2) Documentation of vulnerabilities collected from source to include, but not limited to:
 - (a) Red Team findings report
 - (b) Cyber Table Top report
 - (c) Vulnerability and configuration scans results
 - (d) DT/OT Cyber Testing
 - (e) Threat and Intel sources
- (3) Effect of exploitation of a vulnerability on the system/component/enclave functionality/performance (this may be identified in the POA&M/CAP):
 - (a) Gain & Maintain Access/Escalate privileges
 - (b) Exfiltrate or corrupt data
 - (c) Disrupt/Deny/Control use of the system or services
 - (d) Observe operations
- (4) System and Defense in Depth (DiD) diagram of operating environment which includes:
 - (a) System components and classification

(b) Location of cyber solutions and services deployed to monitor/mitigate risk, to include cross domain solutions

(c) Install location(s)

(d) Internal/external connections

i. Classification of data

ii. Type of interface (i.e. Ethernet/serial and logical, UDP)

1. Include service type/function (i.e. FTP, track message, etc)

iii. Direction of information flow

(5) Mission impact:

(a) Function of the system/component in the supporting mission (AAW, SUW, EW, etc) and geographic area(s); considering impact to system, enclave, and platform

(b) Impact to Strike Group / Strike Force / Joint Operations based on the effect of vulnerability (does the effect result in a mission failure, mission degradation, etc)

(c) Understanding of available workarounds, including alternate systems and manual processes

Table 11. RASC - Assess Security Controls

	Task Description <i>What is the action?</i>	Responsible <i>Who is actually doing the work?</i>	Accountable <i>Who gets in trouble when something goes wrong?</i>	Supporting <i>Who can the responsible party direct to help?</i>	Consultable <i>Who should the responsible party ask for advice?</i>
4.1	Submit SAP for approval to SCA Liaison and SCA via the SAP Approval workflow.	NQV	NQV	ISSM, ISSE	PSO, SCA Liaison
4.2	Perform the official security assessment against the Approved SAP	NQV	NQV	ISSM, ISSE	PSO, SCA Liaison
4.3	Initiate the SAR based on findings from the risk assessment and provide to Program	NQV	NQV	ISSM, ISSE	PSO, SCA Liaison
4.4	Remediate findings and/or implement mitigating controls, as possible	ISSE	PM / SO	ISSM	NQV, PSO, SCA Liaison
4.5	Update the POA&M to reflect unresolved cybersecurity vulnerabilities from the SAR	ISSM	PM / SO	ISSE	NQV, PSO, SCA Liaison, AO CSA
4.6	Validate and submit the SAR and SAR Executive Summary to the SCA	NQV	NQV	ISSM, ISSE	PSO, SCA Liaison

4.7	Direct any necessary adjustments and approve the SAR once concurrence is reached. <i>This approval should include an authorization recommendation with any corresponding conditions that should be met by the Program Office following authorization</i>	SCA	SCA	SCA Liaison, NQV, PSO, PM / SO	AO CSA, AO
-----	--	-----	-----	--------------------------------	------------

4.4.2. Develop SAP

The Validator, with the support of the program, develops the SAP which must assess all of the controls documented in the SP. SAP approval is achieved through executing the SAP approval workflow in eMASS. Appendix C of this guide discusses the SAP in detail.

The staff managing systems inheriting security controls are not obligated to validate inherited controls. That staff is responsible for maintaining situational awareness of changing conditions and risks of inherited controls, and for proper mitigation.

4.4.3. Assessment Responsibility

The PM/SO ensures the appropriate tests, inspections, and analyses are completed to assess every applicable system-specific or hybrid security control associated with the system. The ISSM oversees the actual assessment in coordination with the ISSE. The Validator executes the assessment plan, develops the SAR, and works with the PM/SO to document the results in the POA&M.

4.4.4. Assessment Types

Reference (r) provides specific instructions on how to perform assessment activities. This guide discusses generally the types of testing performed that the Validator identifies in the SAP, and the SCA and AO approve.

4.4.5. Control Assessment Procedures

Security control assessment procedures can be found in eMASS and on the USN RMF Portal for each security control identified as part of a system's baseline. Assessment procedures may require artifacts to demonstrate compliance, in which case those artifacts must be uploaded to eMASS unless the SCA or AO directs otherwise.

Each assessment procedure is associated with measurable individual statements as dictated by reference (o). Each statement is given a number called a CCI. It is important that Validators ensure CCIs are assessed in coordination with the necessary SRGs and STIGs where appropriate.

4.4.6. Automated Scans and Other Assessment Types

Reference (r) discusses automated scans and manual checklists in greater detail. It is important that Validators provide the test results from these scans and checklists as dictated in reference (r), and upload them as an artifact to eMASS.

4.4.7. Assessment Results

The ISSE enters the test results and marks all applicable assessment procedures as either Compliant (C) or Non-Compliant (NC). The ISSE then initiates the Control Approval Chain (CAC) and submits the security control to the validator for certification/validation. The CAC is an embedded step in the 'RMF Step 4+5: Assess & Authorize' and 'Risk Assessment' workflows. The validator approves/rejects the submitted test results. All open findings and vulnerabilities must be identified in the POA&M, and all NC security controls must be documented in the SAR. If applicable, Validators review the system's previous POA&M and address any open vulnerabilities in the new assessment. The Validator assesses the test results performed by the ISSE and identifies all validation procedure results in the eMASS security control record.

For inherited security controls, the providing system maintains assessment test results and supporting documentation, and makes them available to the SCA on request. For common controls inherited from the enterprise, instructions for documenting compliance are provided on the USN RMF Portal. The Validator should maximize the reuse of existing assessment (i.e., a leveraged authorization), and test and evaluation (T&E) documentation in their assessment of the system.

The Validator performs the official security assessment and records the results in the CAC at the appropriate RMF authorization workflow step. The PM/SO and ISSE remediate or mitigate any discovered vulnerabilities. Updated testing artifacts will need to be provided to demonstrate vulnerabilities have been remediated. The Validator works with the ISSM to update the POA&M to include vulnerabilities from the formal assessment. The Validator develops the SAR based on the results of the assessment and submits the SAR to the SCA Liaison for review and SCA approval. The ISSM updates the POA&M based on the assessed open vulnerabilities in the SAR.

There is a distinct difference between Step 3 testing and Step 4 assessment. Step 3 testing is used by ISSEs to evaluate if a specific control is implemented properly. In Step 4, the Validators verify that the implementation from Step 3 satisfies the control requirements and perform further risk analysis.⁷

The SAP provides the objectives for the security control assessment, describes procedures and tools used, and records assessment findings not captured anywhere else. The SAP distinguishes the type of assessment the organization is performing (e.g., developmental testing and evaluation; independent verification and validation; assessments supporting security authorizations or reauthorizations; or audits).

4.4.8. Inputs, Outputs, and Tools Required

Table 12. Inputs, Outputs, and Required Tools of RMF Step 4

Input	Output	Tool Required
-------	--------	---------------

⁷ The official security assessment must be supported by new assessment results achieved by the use of Navy testing tools. If results from preliminary control testing are used to support the official security assessment, those findings must be reported in official reports. The Security Assessment Plan will be executed during Step 4 (Assessment), as the validator is using those tests to assess the control implementation that was performed in RMF Step 3. The Validator may use existing test results to assist in performing the assessment during Step 4 as long as it still results in a set of testing that is true and correct. If test results from Step 3 are used, this must be noted.

3.1 Updated Security Plan (SP) and Security Assessment Plan (SAP)	4.1 Updated Security Plan <i>This update reflects the actual state of the security controls after the initial assessment, including modifications to implement corrective actions</i>	<u>eMASS</u>
4.1 Updated SAP	4.3 Completed SAP	Approved Testing Tools and Methodologies
4.2 Navy Qualified Validator (NQV) Assessment Results		Reference (r) – Navy Security Control Assessor (SCA) Risk Assessment Guidance <u>http://cyber.mil</u> <u>eMASS</u>
4.3 Completed SAP	4.4 Security Assessment Report (SAR)	<u>eMASS</u>
4.4 SAR	4.5 Updated POA&M <i>This is based on the assessed open vulnerabilities in the SAR</i>	<u>eMASS</u>
4.1 Updated SP	4.6 Security Authorization Package	<u>eMASS</u>
4.3 Completed SAP		
4.4 SAR		
4.5 Updated POA&M		

4.4.9. Perform Security Control Assessment

In Step 4, the Validator performs and documents the results of the official security assessment in the CAC at the appropriate RMF authorization workflow step. The Validator records false positives and misleading results in the SAP. The PM/SO and ISSE remediate and mitigate any discovered vulnerabilities. DISA provides a list of all of the applicable SRGs, STIGs, and Security Content Automation Protocol (SCAP) benchmarks (optional) that should be downloaded for use in the security control implementation and testing on the DoD Cyber Exchange (<https://cyber.mil>). The test team will use Navy-approved testing tools in this step. OPNAV maintains a list of additional approved Navy RMF tools on the USN RMF Portal.

4.4.10. Initiate SAR

The Validator documents their findings in a control level assessment in the Risk Assessment tab in eMASS, which informs the SAR. The NQV provides their results to the PM/SO and ISSE for updating the POA&M (this can also be done by importing the risk assessment in eMASS). The Validator prepares the SAR based on any updates identified during the review process.

4.4.11. Update POA&M

The PM/SO and ISSM update the POA&M with the open findings from the SAR (the Validator will verify all NC controls are documented in the POA&M). The PM/SO and ISSE will then remediate or mitigate any new vulnerabilities discovered during the assessment, and then update the POA&M. The PM/SO and ISSM use the POA&M to focus on risk assessment of open

vulnerabilities whenever a vulnerability is discovered. The PM/SO and ISSE must perform a risk assessment on all open vulnerabilities per reference (s) and the current CSTA Cyber Risk Assessment Standard. They must then assign a risk level to each NC security control.

The SCA's recommendation to the AO on acceptance of the cybersecurity risk of operating the system in the SAR Executive Summary is informed by the individual risk levels. Once initiated, the POA&M remains active throughout the system life-cycle.

4.4.12. Finalize the SAR

The Validator updates the SAR in eMASS utilizing the Step 4 SOP and the information contained in the updated POA&M. The SCA Liaison reviews the final SAR and SAR Executive summary and submits with a recommendation to the SCA for final statement of overall system cybersecurity risk. The SCA reviews the SAR Executive Summary and signs the SAR stating the overall system cybersecurity risk.

The following descriptions have been tailored from the definitions in reference (s) and will be used by all Navy systems to assess risk to mission and can be tailored to meet the system/enclave/platform mission.

The likelihood factor for cybersecurity risk is defined as:

(1) Very high likelihood is the adversary has access to and is almost certainly able to initiate the threat event.

(2) High likelihood is the adversary has access to and is highly able to initiate the threat event.

(3) Moderate likelihood is the adversary has limited access to and is somewhat able to initiate the threat event.

(4) Low likelihood is the adversary has very limited access to and is unlikely able to initiate the threat event.

(5) Very low is the adversary does not have access to and is highly unable to initiate the threat event.

Cyber impact will prioritize harm to operations and missions and will focus on harm caused by a cyber adversary. Given the above definitions of likelihood and the impact, the overall risk is calculated:

(1) Very high risk is defined as a threat event could be expected to have multiple severe or catastrophic (involving sudden great damage) adverse effects on Naval operations and assets, or the Nation. An example of a very high risk threat event is one which provides privileged access to other systems without authentication resulting in a significant impact to the interconnected system / enclave.

(2) High risk is defined as a threat event could be expected to have a severe or catastrophic adverse effect on organizational operations, organizational assets, or the Nation. An example of a high risk threat event is one which provides unprivileged access to other systems without authentication resulting in a significant impact to the interconnected system / enclave.

(3) Moderate risk is defined as a threat event could be expected to have a serious adverse effect on organizational operations, organizational assets, individuals, other organizations, or the Nation.

(4) Low risk is defined as a threat event could be expected to have a limited adverse effect on organizational operations, organizational assets, individuals, other organizations, or the Nation.

(5) Very low risk is defined as a threat event could be expected to have a negligible adverse effect on organizational operations, organizational assets, individuals, other organizations, or the Nation.

4.4.13. Resource POA&M

Resourcing the POA&M is a PM/SO responsibility. The PM/SO is responsible for detailing the solutions, application of resources, milestones, and scheduled completion dates.

4.4.14. Prepare Security Authorization Package for Review

If applicable, the final PPSM Registration must be uploaded for a final review.

The PSO determines if the package is ready for submission utilizing the Step 5 SOP for review. If the PSO has issues, they must be addressed at this time. If the package is inaccurate, it must not be forwarded for adjudication. If the package is incomplete, the PSO is responsible to determine if the issues impact an authorization decision. These administrative findings from the review are to be annotated in the POA&M.

Once the PSO determines the Security Authorization Package is ready for adjudication by the AO, the PSO pushes the package to the AO via the eMASS workflow. Refer to Appendix A of this guide for further guidance on preparing the Security Authorization Package for AO review.

4.5. RMF Step 5 - Authorize System

In Step 5, the AO CSA processes the package; the PSO, in coordination with the program, opts whether to hold the optional RMF Step 5 Checkpoint based on key stakeholder feedback; and the AO CSA submits to the AO for an authorization decision.

Table 13. RASC - Authorize System

	Task Description <i>What is the action?</i>	Responsible <i>Who is actually doing the work?</i>	Accountable <i>Who gets in trouble when something goes wrong?</i>	Supporting <i>Who can the responsible party direct to help?</i>	Consultable <i>Who should the responsible party ask for advice?</i>
5.1	Submit Security Authorization Package to the AO	ISSM	PM / SO	ISSE	NQV, PSO, SCA Liaison
5.2	(Optional) Coordinate and schedule the RMF Step 5 Checkpoint between the AO CSA, SCA Liaison, and Program Office	PSO	PSO	PM / SO, SCA Liaison, AO CSA	---
5.3	Process the Security Authorization using the SOP. Package and submit to the AO for an authorization decision.	AO CSA	AO	PSO, SCA Liaison, PM	NQV, ISSM, ISSE
5.4	Review Security Authorization Package and make authorization decision	AO	AO	AO CSA, SCA, PSO	NQV, SCA Liaison, PM
5.5	Generate the Authorization Decision Document containing terms and conditions for the authorization and the authorization termination date	AO	AO	AO CSA, SCA, PSO	SCA Liaison, NQV, PM
5.6	Add all ATO stipulations to the POA&M and associate as a System vulnerability	ISSM	PM/SO	ISSE	NQV, PSO, SCA Liaison, AO CSA

4.5.1. Inputs, Outputs, and Tools Required

Table 14. Inputs, Outputs, and Required Tools of RMF Step 5

Input	Output	Tool Required
4.6 Security Authorization Package	5.3 Updated Security Authorization Package 5.4 Authorization Decision Document <i>Contains the authorization decision, terms and conditions for the authorization, and the authorization termination date</i>	<u>eMASS</u>
5.1 System Level Continuous Monitoring (SLCM) Strategy		
5.2 PPSM Registration Form		

eMASS is the repository for storing the required documentation to complete the final Security Authorization Package, including the final POA&M, SAR, and authorization decision.

4.5.1.1. Inputs Required

Inputs for Step 5 include the system categorization, SP, SAP, POA&M, SAR, SLCM Strategy, PPSM Registration form (if required), and supporting documentation, as identified by the AO CSA in Step 2. All these artifacts comprise the Security Authorization Package.

4.5.1.2. Output

The output for Step 5 is an Authorization Decision Document. The authorization decision document contains the authorization decision, terms and conditions for the authorization, and the authorization termination date.

4.5.2. AO CSA Security Authorization Package Review

The AO CSA reviews their respective portions of the Security Authorization Package leveraging the Step 5 SOP. As discussed in Appendix A, this review includes any additional artifacts required for the system. As a result of the review, the AO CSA either sends the package back for updates or moves it forward for a final statement of risk and the authorization decision.

4.5.3. Optional RMF Step 5 Checkpoint

The PSO, in coordination with the program, is responsible for deciding whether to schedule and conduct the optional Step 5 checkpoint in order to resolve any concerns identified by the reviewers. Appendix H of this guide discusses checkpoints in greater detail.

4.5.4. AO Risk Determination

The AO CSA determines if the provided package represents a compliant system with an initially acceptable level of operational risk.

4.5.4.1. High or Very High Risk Systems

If the level of risk meets the High residual risk threshold as identified by a Security Control Assessor (SCA) signed risk assessment it requires component CIO approval. For this, the PM/SO coordinates with the AO via the PSO to determine if it can enter the Navy High Risk Review (HRR) process, as defined by the current HRR standard operating procedure (SOP), or if it needs to be returned for rework. If overall system risk is determined to be justified due to mission criticality, then the authorization decision will be issued in the form of an ATO with conditions, and only following approval of DON CIO issued via the HRR Process. Follow-on ATOs with conditions will be issued in compliance with reference (a).

4.5.5. AO Authorization Decision

The AO considers the current security state of the system (as reflected by the risk assessment and recommendations provided in the SAR), and weighs it against the operational need for the system. The AO must also consider any applicable risk-related guidance from the DoD Senior Information Security Officer (SISO), Principal Authorizing Officials (PAOs), DoD Information Security Risk Management Committee (ISRMC), Defense Information Assurance Security Accreditation Working Group (DSAWG), DON SISO, DON Deputy SISO or mission owners. Weighing these factors, the AO renders a final determination of risk to DoD operations, assets, individuals, other organizations, and the Nation from the operation and use of the system.

4.5.6. Authorization Decision

An authorization decision applies to a specifically identified system or enclave/platform and balances mission need against risk to: the mission; the information being processed; the broader information environment; and other missions reliant on the shared information environment. To do so, the AO performs a final risk review to determine the risk to organizational operations, organizational assets, individuals, other organizations, or the Nation. The AO then issues an authorization decision as an ATO, an ATO with Conditions, an IATT, or a DATO. This decision comes in the form of an Authorization Decision Document. A system is considered unauthorized until an authorization decision is made.

When ongoing authorization requirements have not been met, the length of an ATO will be based on level of confidence of the BOE, SCA's risk assessment, and AO's risk management decision.

When the cognizant AO determines risk is unacceptable, after factoring in mission criticality, the decision to not authorize will be issued in the form of a DATO. If the system is already operational, the AO will issue a DATO which will be passed to the operational commanders to stop operation of the system immediately. Network connections will be immediately terminated for any system issued a DATO.

4.5.6.1. IATT

An IATT will be issued for temporary activation of a system for the purposes of integration testing, interoperability testing, proof of concept testing, or exercises. Upon termination of the IATT period, the system must be uninstalled and removed; all affected environments returned to their original configuration; and all firewall exceptions and port activations removed.

In accordance with reference (a), IATTs should be granted only when an operational environment or live data is required to complete specific test objectives. Operation of a system under an IATT in an operational environment is for testing purposes only, and for full and independent operational testing, an ATO (rather than an IATT) may be required.⁸

The IATT will provide the beginning and ending dates that testing is authorized, and any specific mitigation requirements. The system may not be used for operational purposes during the IATT timeframe. An IATT may not be used to authorize installation of a system prior to obtaining an initial ATO or for System Operations Verification and Testing (SOVT).

As outlined in Appendix I, the RMF IATT Process will be streamlined by combining Steps 1 & 2, IATT overlays, simplified assessment requirements, and modified artifacts. Streamlining the process for IATTs is not intended to eliminate key requirements (i.e., SCA signed SAR, AO signed Authorization Document), but will facilitate rapid prototyping for the Navy domain.

4.5.7. Periodic Reassessment

The DON is currently developing an ongoing authorization process, and if a system does not meet the Navy criteria for ongoing authorization the systems will be required to undergo periodic reassessment and reauthorization based on the cognizant AOs requirements. For any system previously authorized under RMF being reauthorized, the Reauthorization Guide in Appendix L can be leveraged.

4.5.8. Ongoing Authorization

Consistent with the expectation set forth in OMB Memorandum M-11-33, “FY 2011 Reporting Instructions for the Federal Information Security Management Act and Agency Privacy Management,” September 14, 2011, a sufficiently robust continuous monitoring program that is compliant with emerging higher-level guidance is a key piece of moving away from periodic reassessment and reauthorization and towards operation under ongoing authorization. As of release of this guide, DoD CIO has not determined that the DoD ISCM program is robust enough to support ongoing authorizations, but upon approval from DoD CIO, guidance will be posted on the USN RMF Portal. Continuous ATO (cATO) and Ongoing Authorization are both terms for the same construct. For the purposes of Navy RMF, Ongoing Authorization is the official terminology.

Once usage of Ongoing Authorizations is approved, the PM/SO of a system operating with an ongoing authorization will immediately report any degradation of system security posture to the AO. The report will include a plan and timeline to restore the security posture to an acceptable level. The AO will communicate to the PM/SO any additional test requirements to validate restoration of the security posture. Once the security posture is restored, the system resumes normal operation. If the AO determines the timeline for the security posture restoration is unacceptable, the AO will rescind the system authorization and issue an ATO with conditions or a DATO, as appropriate. Typically, temporary degradation of the system security posture will not impact the decision to allow ongoing authorization since the vulnerability is in the system and not in the continuous monitoring strategy, and once an acceptable security posture is restored the system will operate under ongoing authorization. The exception is when the vulnerability directly affects the continuous monitoring strategy/program.

⁸ Interim Authority to Operate (IATO) is no longer an authorization decision type in the Navy RMF process.

4.6. RMF Step 6 - Monitor Security Controls

Step 6 is where the security controls are monitored and maintained for the life of the system, re-authorizing as required for system updates or periodic reauthorization. RMF Step 6 comprises two sub-processes:

- Periodic; annual security review, patching and scanning, and SLCM execution
- Condition-based; Incident response, CTO, Cyber Security Inspection (CSI) and Command Cyber Readiness Inspection (CCRI) findings, and decommissioning

Any time events require corrective actions, or the system's level of risk exceeds the acceptable tolerance level, the program takes necessary corrective actions. If the level of risk cannot be returned to the acceptable level, the PM/SO will request a new assessment (and authorization if applicable) and re-enter the RMF process.

Appendix F of this guide discusses the SLCM Strategy in greater detail.

Per reference (p), the goal of RMF Step 6 is to maintain an ongoing situational awareness in near real time of the security and privacy posture of the information system and the organization in support of daily operations. This is completed through:

- (a) Monitoring system and environment changes
- (b) Ongoing assessments
- (c) Ongoing risk response, to include a C2 construct and cyber incident response plan
- (d) Authorization package updates.
- (e) Security and privacy reporting
- (f) Ongoing authorization
- (g) System disposal

To further refine references (s) and (p) continuous monitoring for Navy is defined as monitoring in near real time the effectiveness of technical solutions deployed to meet critical system and/or system-of-system requirements to provide operational picture of cybersecurity risk, mission readiness, and to support informed decisions.

To enable Ongoing Authorizations, programs must have established as near real time continuous monitoring capabilities as feasible (can be inherited), complete full RMF authorization, maintain system configuration, and vulnerability management posture to include cyber directive compliance, scan periodicity, and patch status.

Table 15. RASC –Monitor Security Controls

	Task Description <i>What is the action?</i>	Responsible <i>Who is actually doing the work?</i>	Accountable <i>Who gets in trouble when something goes wrong?</i>	Supporting <i>Who can the responsible party direct to help?</i>	Consultable <i>Who should the responsible party ask for advice?</i>
6.1	Implement SLCM Strategy agreed to in the final authorization decision document	ISSM	PM / SO	ISSE	PSO, SCA Liaison
6.2	Track compliance of the associated security controls throughout the lifecycle of the system	ISSM	PM / SO	ISSE	PSO, SCA Liaison
6.3	Ensure the implemented SLCM Strategy contains provisions for effectively communicating security findings up- and down- stream	ISSM	PM / SO	ISSE	PSO, SCA Liaison
6.4	Execute AO approved review requirements in the SLCM	ISSM	PM / SO	ISSE	PSO, SCA Liaison

4.6.1. Inputs, Outputs, and Tools Required

Table 16 . Inputs, Outputs, and Required Tools of RMF Step 6

Input	Output	Tool Required
5.3 Security Authorization Package <i>Includes the approved SLCM Strategy</i>	6.1 Continuously updated Security Authorization Package <i>This must track the compliance of the associated security controls over the lifecycle of the system</i>	<u>eMASS</u>
5.4 Authorization Decision Document		

Section 5: Lifecycle Maintenance

5.1. Maintain Authorization

Once the authorization is obtained:

- Maintain compliance with all newly released STIGs. When a STIG included in the SAP is updated, the ISSM must complete testing. It is not necessary to retest the entire STIG, just the new requirements. When a new STIG is released for technology that the system uses but that was not tested in Step 4, the ISSE is responsible for ensuring the STIG is implemented by the system. Any new findings must be added to the ongoing eMASS POA&M. The ISSM will notify the AO in accordance with the DoD Continuous Monitoring Critical Control guidance (red, yellow, white)
- Conduct scans in accordance with periodicity requirements in FLTCYBERCOM EXORD 20-064, upload scans in VRAM, and document results in the eMASS POA&M

- Maintain compliance with all released cyber directives such as, but not limited to: Operation Orders (OPORD), CTO, Information Assurance Vulnerability Alerts (IAVA), Information Assurance Vulnerability Bulletins (IAVB), and Information Assurance Technical Advisories
- Track completion of identified deficiencies in the eMASS POA&M in accordance with approved timelines, and report any deadlines not met to the AO

5.2. Maintaining Cyber Currency

In accordance and alignment with reference (ae), it is critical for Navy systems to maintain Cyber Currency as it pertains to hardware and software in operational environments. A key to Cyber Currency is reducing time to deploy critical updates to both hardware and software on an ongoing basis while ensuring appropriate visibility and transparency to AOs and Cyberspace Operational Commander (i.e., FLTCYBERCOM) in order to maintain currency of operational authorizations.

In order to reduce time to deploy critical updates, routine cyber hygiene activities (e.g., maintenance, patching, etc.) that address vulnerabilities to existing versions of hardware and software do not require an AO authorization. Additionally, upgrades to COTS/GOTS products that implement minor functions and enhancements to authorized (i.e., ATO) and installed baselines do not require AO approval. This only applies to Programs that have an established Annual Security Review (ASR) process that incorporates software and hardware upgrades and assessments into ASR cycles.

Major hardware/software upgrades that could have significant impact on the cybersecurity and privacy posture of systems, generally require an update to the ATO baseline following the guidance of the cognizant AO once a Navy-approved risk assessment (e.g., SAR) has been completed. Major system hardware or software upgrades include, but not limited to, operating system (OS), OSI layer 2/3 hardware/software infrastructure, and related categories. Upgrades to the ATO baselines of this nature will be at the discretion of the cognizant AO with reference to required actions.

When a major upgrade and operational use is required prior to completion of required RMF tasks, a program designated FO/SES must formally request and receive AO and FLTCYBERCOM approval prior to operational use. AO will communicate standardized body of evidence required to expedite decision for these needs. Approval is at the discretion of the cognizant AO, as this process is an exception and not intended to replace the regular major upgrade process. If the AO approves the major upgrade, cognizant PSO must coordinate and expedite finalization of all required RMF tasks must submit to cognizant AO within 45 calendar days for authorization decision. Factors AOs must consider when deciding on upgrade and operational deployment include, but not limited to, mission/operational impact, FLTCYBERCOM operational orders, execute orders and tasking orders, and other supporting documentation as determined by the cognizant AO.

5.3. Annual Security Review

All applicable security controls identified in the SLCM for monitoring every 2 years, 3 years, or undetermined periodicity will be re-assessed, with the goal that every control from the annual security review pool being assessed at least once every three years. These annual security reviews (ASRs) and assessments are required in order to satisfy DoD requirements. All applicable security controls must be assessed at least once every three years. ASRs will be

conducted in accordance with the approved SLCM Strategy. Refer to the ASR SOP for detailed process guidance.

The ISSM, in coordination with other appropriate personnel (e.g., ISSE, system administrators, Computer Network Defense Service Provider (CNDSP), Cybersecurity Service Provider (CSSP)):

- Continuously monitors the system and operational environment for security-relevant events. Additionally, configuration changes must be monitored to ensure that security posture is not negatively affected. Report any significant change in the security posture of the system, and recommended mitigations immediately to the SCA and AO. When necessary, recommend to the SCA or AO a reassessment of any or all security controls
- Periodically assesses the quality of security controls implementation against performance indicators, such as: security incidents; feedback from external inspection agencies (e.g., Office of the Inspector General (OIG) DoD, Government Accountability Office (GAO)); exercises; and operational evaluations, including Director and Operational Test and Evaluate (OT&E) IA assessments

The results of the annual assessment must be documented in a digitally signed SAR by the cognizant SCA. This will include a recommendation for either no change to the authorization status or issuance of a DATO. The POA&M will also be updated as appropriate. The AO will review the SAR in light of mission and information environment indicators and determine a course of action that will be provided to the responsible CIO or SISO for reporting requirements as described in FISMA. An AO may downgrade or revoke an authorization decision at any time if risk conditions or concerns warrant.

The ISSM must annually assess a subset of the security controls employed in accordance with the SCA- and AO-approved system-level continuous monitoring strategy. The SLCM Strategy must contain the annual review plan; identify in eMASS the “Year-One,” “Year-Two,” and “Year-Three” controls within the Implementation Plan; and provide an overview of the system’s Annual Review process to support the AO’s approval of the overall continuous monitoring strategy. Each annual review will include verification of compliance of inherited controls within those families. The remaining controls should be reviewed as families with the following schedule:

- Year-One: AC, AU, CP, IR, MA, MP, PS, SA, and SI
- Year-Two: AT, CA, CM, IA, PL, PM, PE, RA, and SC
- Year-Three: AR, as well as all remaining controls that were not reviewed during Years One and Two.

The steps below provide a high level overview of the ASR process. For detailed procedures refer to the ASR SOP:

1. ISSM identifies and documents changes to the system environment. Determine if the system configuration or architecture has changed or needs to be modified to accommodate new operational or cybersecurity requirements.
2. ISSM determines impact of changes to the system and environment. Determine the security impact of proposed or actual changes to the system and its environment of

operation. Included in the security controls assigned to all systems are security controls related to configuration and deficiency management, performance monitoring, and periodic independent evaluations (e.g., penetration testing).

3. Perform needed remediation. The SO and Common Control Provider perform remediation actions based on the results of ongoing monitoring activities, assessment of risk, and outstanding items in the POA&M. Systems with a current ATO that are found to be operating in an unacceptable cybersecurity posture through either Director, OT&E IA assessments; General Accounting Office (GAO) audits; OIG DoD audits; or other reviews or events (such as an annual security review or risk assessment) must have the newly identified vulnerabilities and associated level of risk added to an existing or newly created POA&M.
4. PM/SO updates security plan and POA&M. The PM/SO ensures the security plan and POA&M are updated based on the results of the system-level continuous monitoring process. The ISSM may recommend changes or improvements to the SCA and AO at any time regarding the implementation of assigned security controls, the assignment of additional security controls, or changes or improvements to the design of the system itself. The ISSM assists the PM in documenting any strategic changes in cybersecurity that should be reflected in the next update to the Cybersecurity Strategy supporting the next milestone decision point in the Program Protection Plan.
5. SCA issues updated SAR. Once the PM/SO has updated the security plan and POA&M based on the results of the continuous monitoring strategy, they will submit to the SCA who will issue a digitally signed SAR.
6. Report security status to AO. The SO and Common Control Provider report the security status of the system (including the effectiveness of security controls employed within and inherited by the system) to the AO on an ongoing basis in accordance with the monitoring strategy.
7. AO reviews reported status. The AO reviews the reported security status of the system on an ongoing basis in accordance with the monitoring strategy to determine whether the risk to organizational operations, organizational assets, individuals, other organizations, or the Nation remains acceptable. This review includes the effectiveness of security controls employed within and inherited by the system.

5.4. Decommissioning

When needed, implement a system decommissioning strategy that executes required actions when a system is removed from service. Before decommissioning, any control inheritance relationships should be reviewed and assessed for impact by the inheriting and inheritable systems. Once the system has been decommissioned, the SP should be updated to reflect the system's decommissioned status, and the system should be removed from all tracking systems such as DITPR-DON, VRAM, etc. The system's eMASS record "Authorization Status" should also be updated to state "Decommissioned". Data or objects in cybersecurity infrastructures that support the DoD Information Enterprise should be reviewed for impact. These include key management, identity management, vulnerability management, and privilege management.

A DATO may not be issued in parallel to implementing a decommissioning strategy for a system. Issuing a DATO to track decommissioning is no longer required.

5.5. Expiring A&A Management Process

Once initially authorized, all systems must maintain a current authorization. All ATOs will be issued with an Authorization Termination Date (ATD) unless the AO determines the system is compliant with the DoD continuous monitoring policy. The system owner will either complete all actions to obtain a new authorization or request a Delay to Disconnect (DTD) for circuit packages or a Conditional Authorization Request (CAR) for all other packages prior to the ATD.

This process is discussed in detail in Appendix L of this guide.

References

- a. Department of Defense (DoD) Instruction 8510.01, “Risk Management Framework (RMF) for DoD Information Technology (IT),” July 19, 2022
- b. NIST Special Publication 800-137 Revision 2, “Information Security Continuous Monitoring (ISCM) for Federal Information Systems and Organizations,” December 2018
- c. DoD Instruction 8500.01, “Cybersecurity,” March 13, 2014
- d. Committee on National Security Systems Instruction 1253, “Security Categorization and Control Selection for National Security Systems,” March 27, 2014, as amended
- e. Federal Information Processing Standard Publication (FIPS Pub) 199, “Standards for Security Categorization of Federal Information and Information Systems,” February 2004
- f. DoD 5200.2-R, “Personnel Security Program,” January 1, 1987, as amended; superseded March 21, 2014 DoDI 5200.2, DoD PSP Change 2, May 11, 2018
- g. DoD Directive 8140.01, “Cyberspace Workforce Management,” October 5, 2020
- h. DoD 8570.03-M, “Information Assurance Workforce Improvement Program,” CH4, February 15, 2023
- i. SECNAV M-5239.2, “DON Cyberspace IT and Cybersecurity Workforce Management and Qualification Manual,” June 30, 2016
- j. SPAWAR Memorandum, “Navy Qualified Validator, 21 October 2018
- k. DoD Instruction 8100.04, “DoD Unified Capabilities (UC),” December 9, 2010
- l. DoD Instruction 8582.01, “Security of Unclassified DoD Information on Non-DoD Information Systems,” June 6, 2012
- m. NIST Special Publication 800-60 Volume 1 Revision 1, “Volume I: Guide to Mapping Types of Information and Information Systems to Security Categories,” August 2008
- n. NIST Special Publication 800-60 Volume 2 Revision 1, “Volume II: Appendices to Guide for Mapping Types of Information and Information Systems to Security Categories,” August 2008
- o. NIST Special Publication 800-53 Revision 4, “Security and Privacy Controls for Federal Information Systems and Organizations,” **December 10, 2020**
- p. National Institute of Standards and Technology (NIST) Special Publication 800-37 Revision 1, “Guide for Applying the Risk Management Framework to Federal Information Systems,” February 2010
- q. Defense in Depth Functional Implementation Architecture (DFIA) Standards
- r. Office of the Navy Security Control Assessor Risk Management Framework (RMF) Risk Assessment Guide Version 1.0
- s. NIST Special Publication 800-30 Revision 1, “Guide for Conducting Risk Assessments,” September 2012
- t. DCNO (N2N6) Memorandum, “US Navy Information Security Continuous Monitoring Program,” December 21, 2017
- u. DDCIO(N) Memorandum, “Assess Only,” 6 November 2018
- v. DDCIO (N) Memorandum, “Information Assurance Technical Authority Standards Compliance,” August 3, 2017
- w. DDCIO (N) Memorandum, “US Navy Risk Management Framework Implementation Strategy,” February 1, 2017
- x. DON CIO Memorandum, “Additional Requirements for Navy High Risk Escalation Packages,” November 9, 2015

- y. Joint VCNO / ASN(RD&A) Memorandum, "Cyber Security Compliance of Information Assurance Technical Authority Standards," November 8, 2016
- z. NAVADMIN 342/20, "Navy Development Security Operations (DEVSECOPS) Guidance," December 2020
 - aa. Navy Ports, Protocols, and Services Management (PPSM) Manual, 29 March 18
 - ab. NAVADMIN 062/21, "Risk Management Framework Standard Operating Procedures," March 2021
 - ac. Navy Security Control Assessor (SCA) Risk Management Framework (RMF) Assessment & Authorization (A&A) Testing Guidance
 - ad. DON CIO Memorandum, "Department of Navy Risk Management Framework Reciprocity," March 2022
 - ae. SECNAV Memorandum, "Strategic Intent for Cyber Ready," 4 August 2022
 - af. OPNAV Instruction 5239.1D, "US Navy Cybersecurity Program," 18 July 2018
 - ag. NAVADMIN 097/19, "Navy Scanning Policy"
 - ah. NAVADMIN 103/20, "Navy Policy for Waivers of Public Key Infrastructure (PKI) and Host Based Security System"
 - ai. FLCYBERCOM EXORD 20-064, "Navy Scanning Policy"
 - aj. DISA Enclave Test and Development STIG Version 1 Release 6, 27 April 2022

Glossary

For any other cybersecurity or information assurance related definitions, the CNSSI 4009 dated 7 March 2022 should be referenced.

Term	Definition
Community of Interest (COI) Information and Communications Technology (ICT)	A collaborative group of users who exchange information in pursuit of their shared goals, interests, missions, or business processes, and who therefore must have a shared vocabulary for the information they exchange. The group exchanges information within and between systems to include security domains.
Continuous Monitoring	Maintaining ongoing awareness to support organizational risk decisions. See information security continuous monitoring, system level continuous monitoring, risk monitoring, and status monitoring. Source: NIST SP 800-37 (reference (p)). The process implemented to maintain a current security status for one or more information systems, or for the entire suite of information systems that the operational mission of the enterprise depends. The process includes: 1) The development of a strategy to regularly evaluate selected IA controls/metrics, 2) Recording and evaluating IA relevant events and the effectiveness of the enterprise in dealing with those events, 3) Recording changes to IA controls, or changes that affect IA risks, and 4) Publishing the current security status to enable information sharing decisions involving the enterprise.
Cybersecurity	Prevention of damage to, protection of, and restoration of computers, electronic communications systems, electronic communications services, wire communication, and electronic communication, including information contained therein, to ensure its availability, integrity, authentication, confidentiality, and nonrepudiation. Defined in National Security Presidential Directive-54/Homeland Security Presidential Directive-23.
Enclave	Collection of information systems connected by one or more internal networks under the control of a single authority and security policy. The systems may be structured by physical proximity or by function, independent of location.
Enterprise-level	An organization with a defined mission/goal and a defined boundary, using information systems to execute that mission, and with responsibility for managing its own risks and performance. An enterprise may consist of all or some of the following business aspects: acquisition, program management, financial management (e.g., budgets), human resources, security, and information systems, information and mission management.
High-Side	The higher security level classification network of a CDS.

Information System (IS)	A discrete set of information resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information. Source: 44 U.S.C. Sec 3502 Note: Information systems also include specialized systems such as industrial/process controls systems, telephone switching and private branch exchange (PBX) systems, and environmental control systems.
Information Technology (IT)	Any equipment or interconnected system or subsystem of equipment that is used in the automatic acquisition, storage, manipulation, management, movement, control, display, switching, interchange, transmission, or reception of data or information by the executive agency. For purposes of the preceding sentence, equipment is used by an executive agency if the equipment is used by the executive agency directly or is used by a contractor under a contract with the executive agency, which requires the use of such equipment; or requires the use to a significant extent of such equipment in the performance of a service or the furnishing of a product. The term information technology includes computers, ancillary equipment, software, firmware and similar procedures, services (including support services), and related resources. Source: 40 U.S.C. Sec. 11101 (adapted); 40 U.S.C. Sec. 1401 (adapted).
Low-Side	The lower security level classification network of a CDS.
Owning Organization	The business owner of the content and belongs to.
Package Submitting Officer (PSO)	The responsible cybersecurity official in the echelon 2 or PEO within the chain of command of the PM/SO. The PSO is responsible for prioritizing, enforcing standardization, and performing quality assurance reviews. This role and function may be executed by an individual appointed by the echelon 2 Commander (e.g. echelon 2 CIO or PEO). The PSO is responsible for providing the echelon 2 CIO with information about all packages submitted and required CIO reporting information and data calls.
Reciprocity	Mutual agreement among participating organizations to accept each other's security assessments in order to reuse information system resources and/or to accept each other's assessed security posture in order to share information.

Acronyms

Acronym	Definition
A&A	Assessment and Authorization
AO	Authorizing Official
AO CSA	Authorizing Official Cybersecurity Analyst
AODR	Authorizing Official Designated Representative
AOR	Area of Responsibility
APT	Advanced Persistent Threat
ATD	Authorization Termination Date
ATO	Authorization to Operate
CAL	Category Assurance List
CAP	Corrective Action Plan
CAR	Conditional Authorization
CCEVS	Common Criteria Evaluation and Validation Scheme
CCI	Control Correlation Identifier (CCI)
CCP	Common Control Provider
CCRI	Command Cyber Readiness Inspection
CIO	Chief Information Officer
CMCS	COMSEC Material Control System
CNDSP	Computer Network Defense Service Provider
CNSS	Committee on National Security Systems
CNSSI	Committee on National Security Systems Instruction
COCO	Commercially-Owned, Commercially-Operated
COI	Community of Interest
COI-ICT	Community of Interest Information and Communications Technology
COTS	Commercial off-the-Shelf
CS	Cybersecurity
CS TA	Cybersecurity Technical Authority
CSI	Cyber Security Inspection
CSSP	Cybersecurity Service Provider
CTO	Communications Tasking Orders
CTS	Computerized Telephone System (CTS)
DADMS	Department of the Navy Application and Database Management System
DATO	Denial of Authorization to Operate
DDCIO(N)	Department of the Navy Deputy Chief Information Officer (Navy)
DDSI(N)	Department of the Navy Deputy Senior Information Security Officer (Navy)
DFIA	Defense-in-Depth Functional Implementation Architecture
DiD	Defense-in-Depth
DIP	DIACAP Implementation Plan
DISA	Defense Information Systems Agency
DITPR-DON	Department of Defense Information Technology Portfolio Repository – Department of the Navy
DoD	Department of Defense

DoDIN	Department of Defense Information Networks
DON	Department of the Navy
DSAWG	Defense Information Assurance Security Accreditation Working Group
DTD	Delay to Disconnect
DT&E	Developmental test and evaluation
eMASS	Enterprise Mission Assurance Support Service
FAO	Functional Authorizing Official
FIPS	Federal Information Processing Standards
FM	Financial Management
FSCA	Functional Security Control Assessor
GOCO	Government Owned Contractor Operated
GOTS	Government-Off-the-Shelf
GSS	General Support System
IA	Information Assurance
IATO	Interim Authority to Operate
IAVM	Information Assurance Vulnerability Management
ICS	Industrial Control System
ICT	Information and Communications Technology
ISCM	Information Security Continuous Monitoring
ISRMC	Information Security Risk Management Committee
ISSE	Information Systems Security Engineer
ISSM	Information System Security Manager
IT	Information Technology
IV&V	Independent Verification and Validation
KS	Knowledge Service
MOU	Memorandum of Understanding
NA	Not Applicable
NAO	Navy Authorizing Official
NC	Non-Compliant
NCS	Navy Control System
NIAP	National Information Assurance Partnership
NIST	National Institute of Standards and Technology
NSI	National Security Information
NSS	National Security System
NQV	Navy Qualified Validator
OPNAVINST	Office of the Chief of Naval Operations Instruction
OS	Operating System
OT&E	Operational Test and Evaluation
PAO	Public Affairs Officers
PIA	Privacy Impact Assessment
PII	Personally Identifiable Information
PM	Program/Project Manager
PMO	Program Management Office
POA&M/POAM	Plan of Actions and Milestones
PPSM	Ports, Protocols, and Services Management

RA	Risk Assessor
RAISE	Rapid Assess and Incorporate Software Engineering
RDT&E	Research Development Test and Evaluation
RMF	Risk Management Framework
RPG	RMF Process Guide
SA	System Administrators
SAP	Security Assessment Plan
SAR	Security Assessment Report
SCA	Security Control Assessor
SISO	Senior Information Security Officer
SITR	SIPRNet IT Registry
SLCM	System Level Continuous Monitoring
SLA	Service Level Agreement
SME	Subject Matter Expert
SO	System Owner
SOVT	System Operations Verification and Testing
SP	Security Plan
SPAV	Security Perimeter Assigned Values
SRG	Security Requirement Guides
STIG	Security Technical Implementation Guide
TAB	Technical Advisory Board
TAE	Technical Area Expert
TPO	Technical Process Owner
UR	User Representative
VOIP	Voice-Over-IP

Appendix A - RMF Minimum Package Requirements

Table 17 identifies the minimum documentation required to prepare a complete Security Authorization Package.

The most recent Security Authorization Package Document List developed for Navy use can be found on the USN [RMF Portal](#) in the Templates folder.

A.1. Additional Authorization Package Requirements

The AO determines the risk to organizational operations (including mission, functions, image, or reputation), organizational assets, individuals, other organizations, or the nation using a variety of elements from the system's Security Authorization Package. The AO considers the current security state of the system, its impact to its hosting environment, and the recommendation provided in the SAR and weighs this against the operational need for the system. In addition, they also consider any applicable risk-related guidance from the DoD SISO, PAOs, DoD ISRMC, DSAWG, DDSISO, or mission owner.

The Common Control Inheritance Agreement template is posted on the Navy RMF Knowledge Service and details for completing it are found in the Navy Enterprise Inheritance Guide. CCPs should also reference the USN RMF Portal and work with the AO.

It is important to ensure that all artifacts uploaded to eMASS for a Security Authorization Package follow the document terms as identified in Table 17. To avoid version confusion, each document must follow this filename naming convention:

SYSTEMACRONYM_DOCNAME_DATE.DOCTYPE

For documents that are part of a Common Control-specific Security Authorization Package, use this filename convention:

CC-PROVIDERNAME_DOCNAME_DATE.DOCTYPE

Table 17. Navy RMF Required Documentation

DoD RMF Term	Description	Navy Term and Acronym	Reference
Security Authorization Package	The set of required documents developed for authorizing officials. The base package contains the security plan, the security assessment report, and the POA&M. The Security authorization documentation is maintained throughout a system's life cycle and includes the authorization decision document, and is the minimum information necessary for the acceptance of an IS system by a receiving organization.	Security Authorization Package	SP 800-37, USN RMF Portal
Security Plan	Provides an overview of the security requirements for a system, and describes the security controls in place or planned for meeting those requirements.	Security Plan (SP)	SP 800-37, 800-18; DoDI 8510.01

DoD RMF Term	Description	Navy Term and Acronym	Reference
Privacy Impact Assessment (PIA)	An initial PIA is required for all Navy IT, regardless of whether PII is collected, maintained, used, or disseminated. Only IT that collect, maintain, use, or disseminate PII are required to complete the full PIA, by: (1) Ensuring PII handling conforms to applicable legal, regulatory, and policy requirements regarding privacy. (2) Determining the need, privacy risks, and effects of collecting, maintaining, using, and disseminating PII in electronic form. (3) Examining and evaluate protections and alternative processes to mitigate potential privacy risks. Review and update of existing PIAs: (1) For DoD IT must be synchronized with the information system's assessment and authorization cycle. (2) For electronic collections must be completed within 6 months of A&A submission. (3) Is required when a significant system change or a change in privacy or security posture occurs.	Privacy Impact Assessment (PIA)	DoDI 5400.16
System Level Continuous Monitoring (SLCM) Strategy	A strategy for maintaining ongoing awareness of information security, vulnerabilities, and threats to support organizational risk management decisions in accordance with the respective organization's risk tolerance.	System Level Continuous Monitoring (SLCM) Strategy	SP 800-37
Security Assessment Plan	Describes the objectives of the security control assessment and provides a detailed roadmap for performing the assessment.	Security Assessment Plan (SAP)	USN RMF Portal
Security Assessment Report	Describes the results of the security control assessment, provides overall risk assessment, and includes recommendations for correcting any deficiencies or vulnerabilities.	Security Assessment Report (SAR)	USN RMF Portal; DoD 8510.01
Plan of Action and Milestones or Corrective Action Plan	Addresses the system's residual vulnerabilities. The POA&M/CAP identifies the tasks to be accomplished, the resources required, milestones for meeting the tasks, and the scheduled completion dates for the milestones. For vulnerabilities with no plan for resolution, a scheduled completion date is not required when risk acceptance is requested, however risk mitigations must still be detailed in the POA&M/CAP.	Plan of Action and Milestones (POA&M)	USN RMF Portal
Vulnerability Scans	Evidence of complete, compliant, and up-to-date vulnerability scans to provide a clear picture of continuous risk monitoring in accordance with the latest Testing Guidance.	Vulnerability Scans	USN RMF Portal

Appendix B - Security Plan

Navy systems will use their eMASS records to store all of the required Security Plan (SP) information.

The DoD RMF KS provides an SP template that can be used to gather the necessary information prior to inputting into the eMASS record, but its usage is not required.

B.1. Security Plan

The Security Plan (SP) is a critical part of the Security Authorization Package that provides the essential architectural and functional information about the system. Not all SPs are developed for acquisition programs with development or integration of new information systems, but when they are, the SP is informed by and initiates the policy and direction of the program's Cybersecurity Strategy. Performance of the plan will strongly influence the update of the Cybersecurity Strategy for the next phase of acquisition and they become mutually supportive documents serving separate and unique purposes. The SP also documents the system's name, acronym, DITPR-DON ID, version information, and points of contact for those responsible for the system during the assessment process.⁹ For all Navy systems, the information in an SP will be entirely contained within eMASS and the SP exported from eMASS during reviews. For the purposes of this guide, the eMASS-exported document is referenced.

The SP is initiated during Step 1 of the RMF process and must be started as early as possible in the program's system development or integration. Step 1 is required in advance of the acquisition program's first milestone decision point. For acquisition programs beginning at Milestone A or B decision point, little more than system architecture may be known. However, the essential information types and information exchanges (if any) are the starting point. System design is not necessary to initiate the SP. It is expected that the SP and other cybersecurity documentation will evolve along with the maturation of the system architecture and design. Consideration must be given to any opportunity for synergy with related systems security engineering efforts such as CYBERSAFE, with its Table Top Criticality Risk Assessment, and Program Protection Planning, with its Critical Program Information (CPI) identification and risk assessment for Trusted System Network Analysis. Much of the information for the SP will be pulled from existing system design and mission description documentation. Specifics on the type of information required in the SP are provided in the following section.

An initial SP is a requirement at the RMF Step 2 Approval; the completed SP is a requirement for the final authorization decision. An initial SP can be pushed forward with administrative findings at the discretion of the PSO. The ISSE and ISSM have responsibility for preparing the SP and ensuring all of the system's information is captured thoroughly and correctly. The ISSE and ISSM must engage the Chief Engineer, Systems Engineer, and, as applicable, the Integrated Product Team (IPT) lead in confirming the compatibility of cybersecurity architecture and design with the overall system design and integration as well as the program manager's planning. Many of the cybersecurity controls, both Security Assurance Controls and Security Function Controls, are part of or impinge on other program management and systems engineering functions and processes. Consequently, buy-in and coordination with the IPT lead and the Chief Engineer with

⁹ Ensure that the system name matches between the eMASS and DITPR records, if applicable.

the selected initial and final security controls is vital. The responsibilities of the ISSE and the ISSM go beyond merely composing the SP for approval; they must have a seat at the table for the tradeoffs needed for securing program resources as described in the SP. The SP must be kept up-to-date at all times, however changes to the SP made during the authorization process prior to Step 5 do not require a return to Step 2, though some changes may necessitate an updated control baseline (it is the responsibility of the program to make the initial determination of if a change is required).

B.2. Security Plan Content

All Navy systems must use eMASS to capture the required SP information for the following fields: System Authorization Boundary, Software List, Hardware/Firmware List, and Information Flows. This section outlines each part of the SP, highlighting what information is required for approval, when each section needs to be completed, and where the information to complete it can be found. It is based on the most recent eMASS version prior to the publication date of this guide.

B.2.1. Information Required for RMF Step 2 Approval

- **System name, acronym, and version number:** Includes the full descriptive system name, the acronym (if applicable), and the specific system version that is being assessed. This information should be available in the System Design Documentation.
- **System Identification (DITPR-DON/DADMS ID):** The numerical system identifier used to uniquely identify the system within DITPR. This number is received when the system is registered in DITPR-DON/DADMS. In the event that the system does not require a DITPR-DON or DADMS record, this field should be filled out in eMASS as “00000”.
- **System Type:** The DoD IT type of the system. The four options are Platform IT, IS Major Application, IS Enclave, or Platform IT System. The system type should be defined in the system’s mission or functional description.
- **National Security System:** Identifies whether the system is NSS. The determining checklist is built into eMASS.
- **System Lifecycle/Acquisition Phase:** Identifies where the system is in the development lifecycle. The selection options are: Pre-Milestone A (Material Solution Analysis); Post-Milestone A (Technology Development); Post-Milestone B (Engineering and Manufacturing Development); Post-Milestone C (Production and Deployment); Post-Full Rate Production/Deployment Decision (Operations and Support). This information should be available in the system’s project management plan or acquisition lifecycle plan and must be updated in the SP as the system matures.
- **DoD Components:** Identifies the PSO that has authorization responsibility for the system. The information owner and the system owner PSOs can be different and the correct selection should be confirmed via the system’s budgeting plan or program management office.
- **Authorization Status:** The current authorization status of the system. Selection options are: Not Yet Authorized, ATO, ATO with Conditions, IATT, and DATO.
- **Governing Mission Area:** The business area that governs the system’s mission requirements. Selection options are: Enterprise Information Environment MA (EIEMA); Business MA (BMA); Warfighting MA (WMA); DoD portion of the Intelligence MA

(DIMA). This information can be found in the DITPR-DON record and should initially come from the system's mission and functional descriptions.

- **System Location:** Identify whether the system will be physically installed at one location, multiple locations, or a cloud configuration. If it will be installed at more than one location, identify whether it is a Type authorization. If a Cloud configuration, specify the Cloud Provider and IL type. This information should be part of the system's mission description.
- **DoD Security Control Set:** Identify which version of the NIST 800-53 is being used as the initial control set baseline for the system. This information can be found on the RMS KS site or via the system's or PSO's ISSM.
- **RMF Team Roles, Member Names, and Contact Information:** The list of personnel assigned to the RMF roles for the system being assessed. Descriptions of these roles and who designates each role can be found in Section 2 of this guide. Roles for RMF include AO, AO CSA, SCA, SCA Liaison, ISSE, ISSM, ISSO, PM/SO, PSO, UR, and Validator. Some of these roles are included in the eMASS registration fields.
- **System Description:** Provide a narrative description of the system, its major components and interfaces and their function, a description of the function of each asset within the authorization boundary, and the system uses. Information identified here should include whether the system is stand-alone or a Cloud configuration and if it is directly or indirectly connected to the Defense Information System Network (DISN). Indicate system network connection (e.g., NMCI, ONE-Net, IT-21) the system is connecting to, if applicable. This information should be available in the System Design Document or the mission and functional requirement documentation.
- **System Authorization Boundary:** A diagram of the system that identifies everything that should be included within the authorization boundary. The diagram shall be sufficiently detailed to identify all components and interfaces being assessed, and should also include the system name, eMASS number, highest classification present within the authorization boundary, and installation location(s) as appropriate. Each block in the diagram shall represent an independent functional unit. Within the authorization boundary on the diagram should only be those items that should be assessed as part of this particular Security Authorization Package. If a component is not to be assessed as part of this Security Authorization Package, it should be outside of the authorization boundary on the diagram, regardless of where it sits physically in location to the system. The authorization boundary must be indicated by a dotted red line. Interconnected systems corresponding with the information provided in the Interconnected Information Systems and Identifiers list should be depicted in the diagram outside the authorization boundary. IP addresses and PPSM registration numbers are not required. The diagram should be uploaded to eMASS as a human-readable file type (.gif and .jpg files do not scale well for viewing). The information to develop the diagram should be part of the system's architecture documentation and the identification of the components within the authorization boundary should be there as well.
- **Hardware:** Update the Hardware Baseline section of the eMASS Assets tab. The Hardware Baseline must be detailed in the eMASS Assets tab, a separate artifact is no longer sufficient.

- **Software:** Update the Software Baseline section of the eMASS Assets tab. The Software Baseline must be detailed in the eMASS Assets tab, a separate artifact is no longer sufficient.
- **System Enterprise and Information Security Architecture:** A brief architectural description of how the system is integrated into the enterprise architecture, as well as the information security architecture. Provide an artifact that includes a Defense in Depth (DiD) diagram of the enterprise and information security architectures that shows how the system is integrated within (DiD guidance can be found on the USN RMF Portal). This architecture should be developed from a combination of the system design documentation and the hosting environment's architectural documentation, including their Security Authorization Package where appropriate. Ship and shore required installation drawings (e.g., Interface Requirements Document (IRD)) should also be used for this information.
- **Information Flows/Paths:** A diagram of the system with all information flows into and out of the system identified, whether external or internal to the authorization boundary. External and internal interfaces shall be shown, and the external equipment or systems that interface with the equipment or system shall also be shown. All registered ports and protocols should be clearly identifiable on this diagram and properly mapped to the PPS table which should identify inbound/outbound traffic. This diagram should be developed based on the system design documentation, as well as a complete PPS scan and review. The diagram shall be compared to software requirements guides for any internal server communications.
- **Network Connection Rules:** A link to or list of the network connection rules for communicating with external systems. Information from the Interconnection Agreements can be used for the description. This list can be developed based on previously developed Interconnection Agreements, MOUs, MOAs, and any functional requirements identified in the system design documentation (e.g., the Interface Description Document (IDD)). The Category Assurance List (CAL) boundaries should also be identified.
- **System Ownership/Controlled:** Identifies the ownership/operation of the system. The options are: DoD Owned and DoD Operated IS and PIT System; DoD Owned and Non-DoD Operated IS and PIT System; DoD Controlled/Non-DoD Owned and Operated IS and PIT System; and DoD-Partnered System. This information should be part of the acquisition documentation.
- **System Categorization:** Identifies the system security category developed as described in Section 4.1 of this guide.
- **Applied Overlays:** Identifies overlays applied to the security control set for the system. This is determined per the process described in Section 4.3 of this guide.

B.2.2. Information Required Only for Final Authorization Decision

- **Authorization Date:** If a system is currently or has previously been authorized, even if the authorization is now expired, enter the date the authorization was issued. This can be found in the authorization letter. If the system has never been authorized, this can be left blank. Required only if applicable.
- **Authorization Termination Date:** Include the end date of the current or previous authorization, even if it has expired. This can be found in the authorization letter. Required only if applicable.

- **Security Review Date:** The date of the last annual security review for systems with an existing authorization, or the last date the system was tested for systems with no prior authorization.
- **Physical Location:** The physical location where the system will be installed. This information should be in the system's mission requirements or budgeting documentation.
- **Software Category:** Select whether the system software is commercial-off-the-shelf (COTS) or government-off-the-shelf (GOTS). If a GOTS product contains COTS software, it should still be selected as GOTS.
- **Interconnected Information Systems and Identifiers:** A list of the interconnected systems with their unique identifiers as found in their respective Security Authorization Packages. At a minimum, the list will include the eMASS number and where available, PPS registration number. This interconnection list requirement can be fulfilled by the PPS table.
- **Encryption Techniques:** Identifies the encryption techniques used for information processing, storage, and transmission. This information should be found in the system design documentation. If inheriting encryption from a hosting environment, reference the hosting environment's solution and eMASS ID (if applicable).
- **Cryptographic Key Management Information:** Identifies the cryptographic key management information. For systems that do not have PKI implemented, non-compliance must be mapped to the applicable security controls. Unclassified information should be FIPS-validated. Unclassified national security information and classified information must use NSA-approved encryption. This information should be found in the system design documentation.
- **System User Categories:** A description of the users and their access rights and privileges for the system. The types of users include: DoD Personnel; Contractors; Federal/State/Local; Organization; Foreign Nationals; Coalition Partners; and the General Public. The user types should be part of the system's mission or functional requirements. The access rights and privileges should be accounted for in the system design documents.
- **Privacy Impact Assessment Required:** All systems must have a PIA completed whether they host Privacy Impact Information (PII) or not. DON systems must answer Yes to this, regardless of whether there is PII on the system. The PIA should be uploaded as an artifact on eMASS when completed.
- **Privacy Act System of Records Notice Required:** Indicates whether a Privacy Act System of Record Notice is required by DoD 5400.11-R, "Department of Defense Privacy Program." This should be in the system design documentation.
- **E-Authentication Risk Assessment Required:** All systems must have an E-Authentication Risk Assessment done through at least the first three questions of the DITPR-DON EAUTH Tab. DON systems must answer Yes to this.
- **Other Information:** This is a box to include any other relevant information about the system, including security-related information discovered or used in the assessment of the system that's not reflected anywhere else.
- **External Security Services:** This table identifies all security services provided by sources external to the system, including through contracts, interagency agreements, SLA, MOA/MOU, lines of business arrangements, licensing agreements, CNDSP, CSSP, and/or supply chain arrangements. Where applicable, include the eMASS ID of the service. The following must be provided for each entry:

- Service description – list of all security services provided by the external provider
- Security requirements description – describe how the external services are protected in accordance with the security requirements of the organization
- Risk determination – documents the necessary assurances have been obtained that the risk arising from the use of the external services is acceptable

Appendix C - Security Assessment Plan Template

The most recent Security Assessment Plan (SAP) template developed for Navy use can be found on the [USN RMF Portal](#) in the Templates folder.

The SAP captures all of the procedures and tools to be used to assess the components identified in the system's authorization boundary for this particular authorization effort. For instance, in the event of a baseline change, the SAP should only capture the assessment methods and targets being evaluated in the targeted assessment. This provides a complete risk assessment of the system and its security controls as a whole. The Validator completes the SAP with input from the system's ISSM and ISSE. The SCA approves the SAP prior to its use during Step 4 assessment activities.

The Validator develops the SAP during RMF Step 4. All Navy systems must use the SAP template. The Validator should use references (r), (o), and (s) to develop the content of the SAP. Reference (s) is the standard risk assessment methodology used to start planning to reinforce reciprocity across DoD communities. The SCA uses the risk assessment to determine the level of overall system cybersecurity risk and as a basis to recommend risk acceptance or denial to the AO. All stakeholders involved in the RMF lifecycle of a system must:

- Ensure security control assessment activities are coordinated with interoperability and supportability certification efforts, Developmental T&E (DT&E) events, and OT&E events
- Where appropriate, integrated testing should include the evaluation of survivability, assessment of controls, and certification testing, as well as DT&E and OT&E

C.1. SAP Content

The SAP template contains the basic format and information requirements that should be included in a cybersecurity test plan for supporting a program or system. Working in conjunction with the program office, the template is intended to be a starting point for the Validator to build on. This template mirrors test plans used to support acquisition functional testing and aligns cybersecurity test events with the appropriate acquisition phase.

Appendix D - Security Assessment Report Template

Navy will use the Security Assessment Report (SAR) within eMASS. The SAR can be exported from the eMASS record as required.

D.1. Security Assessment Report

The Validator uses the SAR to document the residual risk of the non-compliant security controls remaining after the risk assessment work is completed in the POA&M. The SAR is created automatically in eMASS once all of the findings are annotated and the security controls compliance status finalized. A signed SAR is required for all systems requiring authorization.

D.2. SAR Content

The SAR discussed here is wholly contained in eMASS. It can be produced as a separate report and is populated from the system information summary and the Risk Assessment Tab in eMASS. The Risk Assessment Tab includes all controls within the baseline, but by default will only

display controls that have been marked non-compliant (NC) in the controls tab. Changing the filter options will change the controls displayed. The Validator uses the initial SAR to communicate findings from the assessment to the PM/SO and ISSE for inclusion in the POA&M. The following is a description of fields in the Risk Assessment Tab, as shown in Figure 3.

Control Acronym	Status	Risk Attributes	Vulnerability Summary	Impact Description	Recommendations	Select
AC-2	NC	Severity: - Relevance of Threat: - Likelihood: (Recommended: None) - Impact: - Residual Risk Level: (Recommended: None) -	-	-	-	☐
AC-2(1)	NC	Severity: - Relevance of Threat: - Likelihood: (Recommended: None) - Impact: - Residual Risk Level: (Recommended: None) -	-	-	-	☐

Figure 1. eMASS Risk Assessment screen

- **Control Acronym** – Populated by eMASS.
- **Status** – Populated by eMASS.
- **Risk Attributes** – The Validator describes the risk attributes (severity, relevance of threat, likelihood, impact, and residual risk) for all NC controls as part of the security control analysis to indicate the severity associated with the identified vulnerability. NC controls are subjected to a risk assessment process that considers multiple factors in producing the risk attributes as described in references (a) and (p). Aggregation and interaction of the open findings under the related control will factor into final control risk level
- **Vulnerability Summary** – Provide a summary for the entire security control that includes vulnerabilities identified during the security assessment
- **Impact Description** – Provide a summary of the potential impact to the mission, information system, organization and organizational assets, other organizations, individuals, or the nation as a result of exploitation of the vulnerability/weakness
- **Recommendations** – A narrative of the Validator's recommendation for correcting control deficiency. This must include a recommendation to Fix/Mitigate/Accept Risk

The Validator will draft and provide an Executive Summary to the SCA Liaison that contains the following points:

- An assessment of overall system cybersecurity risk (Very High, High, Moderate, Low, or Very Low; see paragraph 4.4.12 of the RPG for risk descriptors), and identify the key drivers for that assessment
- A synopsis of the assessment report focusing on the control assessment, including an overall description of security posture and an overall recommendation for authorization
- Recommendations for correcting or accepting any deficiencies

The SCA uses the draft Executive Summary to populate eMASS prior to digitally signing the SAR.

Appendix E - Plan of Actions and Milestones Template

Navy will use the Plan of Actions and Milestones (POA&M) within eMASS. The POA&M can be exported from the eMASS record as required. A blank template can be exported from eMASS and filled out to be used to import POA&M items into the eMASS record in bulk, as per the eMASS User Guide instructions.

E.1. Plan of Action and Milestones (POA&M)

The PM/SO and ISSM uses the POA&M to identify and monitor the plan to correct weaknesses and deficiencies in the security controls found during the security assessment. The POA&M must align with the acquisition program's development, test and evaluation, deployment and sustainment phases as shown in the program's lifecycle in the integrated master schedule (IMS). POA&M dates can stretch beyond the three year authorization window and should be accurate to the implementation plan. The POA&M is also used by inspectors general (IGs) in their security performance evaluations of agencies, and by Office of Management and Budget (OMB) for oversight responsibilities. eMASS is to be used as the central repository for a system's POA&M and should be accessible through the system's entire lifecycle.

POA&Ms are permanent records. An entry made onto a POA&M can be closed, but not removed. The POA&M addresses: (1) any operational restrictions imposed to lessen the risk during a conditional authorization; (2) specific corrective actions necessary to implement all assigned security controls correctly; (3) the agreed upon timeline for completing the corrective actions; and (4) the resources necessary to complete the corrective actions.

The PM/SO, at their discretion, may request risk acceptance of documented vulnerabilities in the POA&M from the AO for the full duration of the authorization period. The AO will document this risk decision (either approve or disapprove) in the authorization decision. PM/SOs must ensure the POA&M clearly depicts a request for risk acceptance for the duration of the authorization in the POA&M artifact. PM/SOs documenting a scheduled completion date for the full duration of the authorization period in order to indicate no plan for resolution, should instead request risk acceptance of the specific failed vulnerability and/or control for the full authorization period and be specific on details of the request and ensure comments explicitly request risk acceptance in the POA&M.

E.2. POA&M Content

The POA&M discussed here is based on the template exported as an Excel spreadsheet in eMASS as of December 2022. The ISSM may initiate the POA&M by listing all of the NC findings and Not Applicable (NA) security controls from the SAR, but it is the PM/SO's responsibility to fill out the remaining POA&M fields for each entry. There are a number of tools, such as eMASSter, to assist in the completion/review of POA&Ms; OPNAV maintains a list of approved Navy RMF tools on the USN RMF Portal.

The top part of the POA&M is basic system identification information.

- **Date Exported:** Date the POA&M was exported from eMASS
- **Exported By:** Who exported the POA&M from eMASS
- **DoD Component:** Owning DoD component

- **System/Project Name:** Full descriptive name of the system and system version number. It is automatically pulled from the system's eMASS.
- **DoD Registration Number:** Unique system identifier used by the DoD Component to uniquely identify the system. It is automatically pulled from the system's eMASS record.
- **System Type:** DoD system information type. It is automatically pulled from the system's eMASS record.
- **POC Name:** The Authorizing Official (AO) responsible for this system. This must be entered manually on the eMASS POA&M page.
- **POC Phone:** Must be entered manually on the eMASS POA&M page
- **POC Email:** Must be entered manually on the eMASS POA&M page
- **OMB Project ID:** Cite project identifier(s) from OMB Exhibit 300, if applicable. This data must be entered manually on the eMASS POA&M page.
- **Security Costs:** This is the total of the roll-up of the security costs for every open vulnerability, if applicable. This data must be entered manually on the eMASS POA&M page.

The remainder of the POA&M addresses each NC or NA entry. All of the following columns must be addressed for each NC item on the POA&M. The Control Vulnerability Description, Vulnerability Severity Value, Security Control Number, Status, and Comments must be completed for NA entries.

- **Control Vulnerability Description:** Describes the vulnerability identified during assessment. This is pulled directly from the assessment procedure entry or technical assessment method (e.g., STIG test case) where applicable. Otherwise it must be manually entered in the NC status for the vulnerability.
- **Security Control Number:** The reference number for the security control that is NC or NA (not due to an overlay). If applicable, also include the enhancement number. This is pulled directly from the assessment procedure entry. Otherwise, it must be manually entered.
- **Office/Org:** The office or organization responsible for resolving the security deficiency.
- **Resources Required:** Estimated funding or manpower resources required to resolve the security vulnerability (i.e., full-time equivalent).
- **Scheduled Completion Date:** Target completion date for resolving the vulnerability. This target completion date can stretch beyond the potential 3-year authorization window and must accurately reflect the resolution timetable. Please note that the initial date entered may not be changed. When a vulnerability severity value is resolved, the agency should note the actual completion date in the Status column. Enter "NA" if risk is accepted for a satisfactorily mitigated vulnerability severity value.
- **Milestone with Completion Dates:** A milestone identifies specific requirements for correcting an identified vulnerability. The initial milestones and completion dates may not be altered. Any changes to the milestones should be noted in the "Milestone Changes."
- **Milestone Changes:** This column includes changes to completion dates and reasons for the changes.

- **Source Identifying Control Vulnerability:** Identifies the source of the vulnerability (e.g., program review, test and evaluation program findings, IG DoD audit, and GAO audit).
- **Status:** One of the following terms should be selected to report status of corrective actions: Ongoing, Completed, Risk Accepted, NA. "Completed" should be used only when a vulnerability has been fully resolved and the corrective action has been tested. Include the date of completion or risk acceptance for a vulnerability. Enter "Risk Accepted" for vulnerabilities accepted by the AO.
- **Comments:** Identifies any additional information required by the organization. If the security control is inherited, cite the originating system. For NA security controls, provide the reason the control is not applicable. Additional information may include anticipated sources of funding and other obstacles and challenges to resolving the security deficiency (e.g., lack of personnel or expertise, development of a new system to replace insecure legacy system).
- **Raw Severity:** The initial or starting severity of the vulnerability prior to implementing mitigations and/or compensating Controls.
- **Devices Affected:** Any affected devices by the vulnerability. If all devices in the information system are affected, state 'all'
- **Mitigations:** Any currently implemented mitigations and/or compensating Controls that will reduce the risk. A planned mitigation or compensating Control cannot lower risk until implemented
- **Predisposing Conditions:** A condition existing within an organization, a mission or business process, enterprise architecture, information system, or environment of operation, which affects (i.e., increases or decreases) the likelihood that threat events, once initiated, result in adverse impacts.
- **Severity Value:** The severity of a vulnerability is an assessment of the relative importance of mitigating/remediating the vulnerability. The severity can be determined by the extent of the potential adverse impact if such a vulnerability is exploited by a threat source.
- **Relevance of Threat:** Determined by identifying potential threat events, relevance of the events, and threat sources that could initiate the events.
- **Threat Description:** Describe the identified threats.
- **Likelihood:** Weighted risk factor based on an analysis of the probability that a given threat is capable of exploiting a given vulnerability (or set of vulnerabilities). Likelihood can be determined as a combination of the vulnerability severity/predisposing condition pervasiveness and the relevance of the threat. This value is automatically calculated as a result of "Severity" and "Relevance of Threat"
- **Impact:** The magnitude of potential harm to organizational operations, organizational assets, individuals, other organizations, or the nation from the threat event.
- **Impact Description:** Describe the identified impact.
- **Residual Risk Level:** Utilized to determine the risk of the associated security control, which informs the overall system risk. This value is automatically determined as a calculation of the "Likelihood" and "Impact" fields.
- **Recommendations:** A summary of the recommended actions to further address the risk of the vulnerability.

- **Resulting Residual Risk after Proposed Mitigations:** The risk level expected after any proposed mitigations are implemented. Proposed mitigations should be appropriately documented as POA&M milestones

Appendix F - SLCM Strategy

The most recent System-Level Continuous Monitoring (SLCM) Strategy example guidance developed for Navy use can be found on the [USN RMF Portal](#) in the Templates folder and can be tailored by system.

F.1. SLCM Strategy

Reference (b) defines continuous monitoring as “maintaining ongoing awareness of information security, vulnerabilities, and threats to support organizational risk management decisions.” The implementation of a robust continuous monitoring program allows an organization to understand the security state of the system over time and maintain the initial security authorization in a highly dynamic operating environment with changing threats, vulnerabilities, technologies, and mission/business functions. Within the Navy RMF process there are two interdependent continuous monitoring activities: continuous strategy development and continuous monitoring execution. These are equally important in establishing and maintaining a robust Continuous Monitoring Program at the system authorization level. The strategy must be executable and the execution must comply with the continuous monitoring strategy as approved by the AO.

In this context and throughout this section on continuous monitoring, a “system” is the target of an assessment and authorization, and could be a system (as typically defined), an enclave, or even a set of common controls under the cognizance of a Common Controls Provider.

F.2. Continuous Monitoring Strategy

During RMF Step 2, PM/SOs and ISSMs ensure an effective continuous monitoring strategy is drafted. The continuous monitoring strategy is finalized and submitted to the AO for approval in Step 5.

Based on the efficacy of the proposed continuous monitoring program, the AO may approve the strategy and either require triennial reauthorization or approve an ongoing authorization.

F.3. Allocation of Security Controls

The PM/SO and ISSM identify each applicable security control as: system-specific, common, or hybrid, as defined by reference (b), so that continuous monitoring responsibility is properly assigned and understood by all interested parties.

F.4. System-Specific Security Controls

It is necessary to provide granularity for system-specific controls requiring continuous monitoring. The PM/SO and ISSM must specifically state in the SLCM Strategy if each system-specific control will be monitored at the operational user level, at the program level, or both. Regardless of whether monitoring a system-specific control is determined to be a program responsibility or an operational user responsibility, the SLCM Strategy must contain provisions for effectively communicating security findings up- and down-stream.

F.5. Inherited Security Controls

If it is determined the inheriting system requires more frequent monitoring of the inherited security control than is provided by the providing system, the inheriting system PM/SO and ISSM provide additional monitoring of that security control to meet its needs. The PM/SO and ISSM describe in the SLCM Strategy the monitoring method and frequency of any inherited

controls requiring additional monitoring. Inheriting systems cannot impose a burden on providing systems.

F.6. Common Controls

If it is determined the inheriting system requires more frequent monitoring of the inherited security control than is provided by the Common Control Provider, the PM/SO and ISSM of the inheriting system provides additional monitoring of that security control to meet its needs. The Common Control Provider describes in the SLCM Strategy the monitoring method and frequency of any common controls requiring additional monitoring. Inheriting systems cannot impose a burden on Common Control Providers.

F.7. Hybrid Controls

Hybrid Controls are security controls that are satisfied through protections provided by a mixture of inherited protections, common protections, and protections inherent to the system being assessed and authorized. The PM/SO and ISSM describe in the SLCM Strategy the allocation of the protections used to comply with each hybrid security control and the monitoring strategy. The monitoring strategy can use the monitoring provided by the providing system and Common Control Provider for any protections they provide, but must incorporate measures to monitor protections inherent to the system itself. The inheriting system PM/SO and ISSM document in the SLCM Strategy when monitoring of inherited or common protections is deemed insufficient, and implement enhanced monitoring as described in the sections below.

F.8. Security Control Monitoring Methods

An effective continuous monitoring program requires both automated and manual processes. Continuous monitoring discussions tend to focus on automated solutions, which are typically used to monitor technical security controls. In some cases, it may be possible to make inferences about the effectiveness of nontechnical security controls based on data collected from automated tools. While it may not be possible to monitor the actual adherence to policies and procedures, it may be possible to monitor the associated security objective in an automated fashion. It is important to understand and appreciate the need to periodically assess the effectiveness of all security controls, particularly non-technical security controls. Data collected from automated tools may not provide feedback on the existence and the effectiveness of nontechnical security controls. This requires automated tools to be supplemented with manual processes and analysis.

F.8.1. Automated Monitoring

Organizations are encouraged to maximize the use of automation to perform security control assessments to help support the concept of ongoing monitoring of the security state of organizational systems. The use of automation facilitates a greater frequency and volume of security control assessments. The ongoing monitoring of security controls using automated tools and supporting databases facilitates near real-time risk management for the system. The PM/SO and ISSM list in the SLCM Strategy each automated tool used and describes the benefits and services it provides at an executive summary level.

F.8.2. Manual Monitoring

Certain security controls (typically non-technical controls) cannot be assessed using automated processes. When security controls not suited for automated monitoring are identified as requiring continuous monitoring, they require periodic manual review. The PM/SO and ISSM

must ensure effective manual procedures are developed and implemented. The SLCM Strategy must provide an overview of the system's continuous monitoring manual processes with sufficient detail to enable the AO to gauge the program's effect and utility in supporting ongoing authorization.

F.9. System Capabilities Review

PM/SOs and ISSMs must review components within the system's authorization boundary as systems changes occur. The review determines whether the information resources being identified as a system: (1) support the same mission/business objectives or functions; (2) have essentially the same operating characteristics and information security requirements; and (3) reside in the same general operating environment (or in the case of a distributed information system, reside in various locations with similar operating environments). Since commonality can change over time, this determination is revisited periodically as part of a continuous monitoring process. The PM/SO and ISSM determine the frequency of this review, but at a minimum it should be performed annually. It should be noted that as a result of this review, no component can be "orphaned" (left in operation but not part of an authorized system). Before a component can be removed from a system's authorization boundary, the PM/SO and ISSM identifies the appropriate system to absorb the component. The PM/SO and ISSM of the absorbing system must acknowledge acceptance of the reassigned component. This reassignment is not required when components within a system are removed from operation.

F.10. Continuous Monitoring Execution

The PM/SO, ISSM, and PSO ensure the continuous monitoring program is implemented in accordance with the SLCM Strategy that was approved by the AO. Changes in the SLCM Strategy require re-approval of the strategy by the AO.

F.11. AO Auditing Functions

The AO retains the right to audit the execution of system SLCM within their cognizance. In the event of an AO audit, it is the responsibility of the PM/SO to provide all requested documentation illustrating execution of continuous monitoring.

Appendix G - Authorization Options Guide

G.1. Introduction

There are multiple options to authorize IT. These options are intended to work together to ensure all assess and authorize requirements are efficiently met. If applied properly, a security control for a system should only be assessed once. For example, a hosted system should not have to test a control that its hosting enclave provides. Additionally, there is not a single approach that is acceptable for every system. It is up to the system owners and system users to coordinate with the AO to determine the option that best fits the situation. For example, the system may be physically and logically located in multiple locations, but can be assessed and authorized as a single system if all assets operate as a single system. If multiple identical instances of a system will be installed, the system can be authorized using one of the four Type Authorization options.

G.2. Enclaves

There are various types of enclaves as a result of customer, architectural, and mission requirements. For the purposes of aiding in determining A&A boundaries, enclaves can be viewed in two types: basic enclaves as described in the Enclave STIG, and special purpose enclaves. In general, basic enclaves are found closer to external boundaries, while special purpose enclaves are located within or behind basic enclaves. A basic enclave will provide primary boundary defense. A special purpose enclave will provide boundary defense between enclaves. Thus it may not be necessary to provide boundary controls to a special purpose enclave boundary if it is provided by a higher level enclave. Where appropriate, refer to the Defense-in-Depth Functional Implementation Architecture (DFIA) Standard for determining enclaves to assist with A&A boundaries.

Basic Enclave (as listed in Enclave STIG):

- a. General Business LAN Enclave
- b. Network Operations Center (NOC) Enclave
- c. Data Center Enclave
- d. Test and development Enclave

Special Purpose Enclaves (The following is not an all-inclusive list):

- a. Weapons Systems Enclave
- b. Control Systems Enclave
- c. Aviation Enclave
- d. Space Platform Enclave
- e. Industrial Control Systems Enclave
- f. Research Enclave

G.3. Community of Interest Information and Communications Technologies

Any system that is not an enclave falls into this category. While Community of Interest (COI) Information and Communications Technology (ICT) are assessed and authorized separately from an enclave they must either inherit all required perimeter Security Controls or provide the perimeter defense Security Controls. The following is a sample and not an all-inclusive list:

- a. Computerized Telephone System (CTS)
- b. Software Defined Radio (SDR) with embedded INFOSEC components (e.g., Cryptographic System/Subsystem, TEMPEST, Tamper)
- c. COMSEC Material Control System (CMCS)
- d. Dynamic Subsystem
- e. Cross Domain Solution (CDS) or Guard System
- f. General Support System (GSS)
- g. Industrial Control System (ICS)
- h. Information System (IS)
- i. Major Application
- j. Minor Application

G.4. Type Authorization

An official authorization decision to employ identical instances of an information system or subsystem (including hardware, software, firmware, and/or applications) in specific environments of operation (CNSSI 4009). There are four strategies to leverage a type authorization: Enterprise-Wide Authorization; Application Only Authorization; Type Authorization; and Site Authorization.

G.4.1. Enterprise-Wide Authorization

Per ref. (a), this is applicable when a system will deploy throughout the DoDIN or DoDIN-N, a single program may be appointed to complete design, development, and testing of the system. A capability can be a single piece of Government Off the Shelf (GOTS) or a system containing GOTS and/or Commercial Off the Shelf (COTS) software. The enterprise-wide authorization addresses the configuration of the capability itself (application only or hardware and operating system), but not the environment it will be deployed in. An enterprise-wide authorization can be completed by a Navy program or be based on reciprocity with another service or agency. An enterprise-wide Authorization is often a leveraged authorization based on reciprocity from another DoD AO; however, this is not required. The system must be developed and tested in a fully STIG compliant environment. Any waivers must be obtained and made available with the system documentation. The authorization will not specify any locations and will only address controls and testing applicable to the capability. All other controls are not addressed (i.e., Operating System configuration, Enclave, IAVM management). The existence of an enterprise-wide authorization does not eliminate the requirement to complete an additional authorization for those controls.

G.4.2. Application Only Authorization

Applicable when the boundary only includes GOTS applications and the program/owner is not responsible for the systems that will host this software. In these situations, the system owner will not complete testing in all possible operating environments. They are only responsible for the controls and testing associated to the application itself. The application must be developed and tested in a fully STIG compliant environment. Upon installation, the hosting site must incorporate the software into the system or site authorization boundary. This leverages the Application Only Authorization for the testing of the application itself.

G.4.3. Location Options (Applicable to all Type Authorization options)

If the type authorization is completed identifying the locations (see “Location Defined” below), documented inheritance agreements must be completed. The system owner (not the hosting location owner) requesting the type authorization is responsible for verifying the hosting location is capable of and will/has implemented all the inherited controls.

If the type authorization is completed without identifying the specific installation instances (see “Undefined Location,” below), the inheritance requirements must be made available to all locations that will host the system. The hosting location (not the system owner requesting the type authorization) becomes solely responsible for verifying inheritance requirements are properly implemented upon install.

In either case, if the system requires any waivers or exceptions or special authorizations (such as approval to host Naval Nuclear Propulsion Information) the system owner must obtain the appropriate authorizations/approvals. This information must be made available to all locations that will host the system. The system owner must renew and maintain these authorizations for the lifetime of the system.

G.4.4. Type Authorization Undefined Location

Applicable when a system is developed for use at multiple locations throughout the DoDIN-N, but not necessarily DoDIN or DoDIN-N wide. The program developing the system is not responsible for funding, installation, or deployment of any instance of the system and does not know or maintain an installation listing. The system must be developed and tested in a fully STIG compliant environment. Any location operating the system must include the system in their Site Authorization and address all inherited controls.

G.4.5. Type Authorization Location Defined

Applicable when a system is developed for use at multiple locations throughout the DoDIN-N but not necessarily DoDIN or DoDIN-N wide. The program developing the system is responsible for funding, installation, deployment, or maintenance of any instance of the system (e.g., NFSAs). The program is responsible for knowing the installation locations and maintaining a listing of installations. The system must be developed and tested in a fully STIG compliant environment. Any location operating the system must include the system in the Site Authorization and address all inherited controls.

G.4.6. Site Authorization

The site authorization identifies all assets at a physical location. This includes those authorized individually and generally associated to a circuit, command, facility or ship. The site authorization will identify all assets at the site and depict the inheritance relationships amongst the separately authorized assets. The site is only responsible for completing full testing on assets not included in an enterprise-wide or COI-ICT authorization. System and enclave authorizations for both type and non-type authorizations will identify Security Controls inherited from the hosting location. The site authorization identifies the compliance status of the inheritable controls.

Appendix H - Navy Checkpoint Process and Requirements

H.1. Checkpoints

The Navy uses optional checkpoints throughout the RMF process to review the quality and accuracy of the output of the RMF steps in preparation/readiness for follow-on RMF steps. Stakeholders can use the optional checkpoints to ask and answer questions, review current authorization package artifacts, and provide appropriate concurrence. Scheduling of RMF Steps 2 and 5 checkpoints is optional and if selected should occur prior to implementation and authorization, respectively. Other checkpoints may be required as needed. PM/SOs and AOs communicate with the PSOs to determine the required process checkpoints and how they will be conducted.

H.2. Checkpoint Process

Checkpoints processes are defined as follows and must be consistently applied across all PSOs.

H.2.1. PSO Responsibilities

Working with the PSO, the system's program decides whether a Checkpoint is necessary and if it is, the PSO schedules, facilitates, satisfies entry criteria, prioritizes package review workflow, and records results from all checkpoints. They also ensure the correct stakeholders are represented for each checkpoint.

H.2.2. Scheduling

The PSOs are responsible for scheduling all checkpoints with the SCA and AO representatives. Each PSO will publish, maintain, and update monthly a checkpoint schedule for the systems under their purview that provides the actual or projected dates of checkpoints for 90 days out and also includes the name of the system, eMASS ID, type of checkpoint (e.g., RMF Step, process, or consultation), and method of checkpoint (e.g., email, phone call, etc.). Checkpoints should be scheduled a minimum of fourteen business days in advance. An adjustment to the checkpoint schedule (reassigning a checkpoint to a different system, changing the date/time, etc.) within fifteen days of the checkpoint requires concurrence from the SCA and AO representatives.

H.2.3. RMF Step 2 Checkpoint

If a checkpoint is requested, representation from the AO, PSO, and system personnel is required. The PSO provides a summary brief of the system describing: the mission (the operational use of the system); an overview of the system and architecture (number of assets, operating systems in use, type of connectivity, etc.); the fielding status (currently in operation, initial installation timelines, estimated decommissioning date, etc.); and any areas of concern that need to be discussed (end of life software/hardware, non-standard PPS, significant technical or administrative deficiencies, etc.).

If concurrence is not reached, the changes required by the AO CSA must be reviewed and completed before returning for another RMF Step 2 Checkpoint.

H.2.4. RMF Step 5 Checkpoint

If a checkpoint is requested, representation from the AO, PSO, and system personnel is required. SCA representation may also be requested to discuss any factors considered in the signed SAR. The PSO provides the status of any actions identified during previous checkpoints and any required supplementary artifact updates (e.g., fielding status or any areas of concern that need to be discussed, end of life software/hardware, non-standard PPS, significant technical or administrative deficiencies).

The outcome of the Step 5 Checkpoint is an initial authorization recommendation by the AO CSA to their respective AO. The final concurrence and recommendation emails from the AO CSA and SCA Liaison (if requested) can be uploaded to eMASS as an artifact.

H.2.5. Consultation Discussions

In addition to the standard Steps 2 and 5 Checkpoints, consultation discussions can be scheduled throughout the Navy RMF process and may be particularly useful in Steps 1 and 2. These discussions help ensure the Security Authorization Package is being developed correctly and address any questions and concerns of architecture, operation, security, etc. The system stakeholders can use these discussions to pre-brief unique situations for SCA and AO input and direction.

Appendix I - IATT RMF Process Modifications

I.1. Purpose and Scope

This appendix defines processes and standards to achieve an IATT authorization from appropriate Navy AOs in the context of DoD RMF policies and instructions. The processes and standards defined in this appendix provide workflows, security controls, and specific tools that appropriately balance the need to test hardened Information and Communication Technology (ICT) on the Navy portion of the DoDIN. The IATT processes defined in this Appendix will support Navy PM/SO, CIOs, PMOs, and other key RMF stakeholders by providing a "leaned" RMF process to achieve an IATT authorization from the designated AO. This appendix does not alleviate RMF stakeholders from meeting requirements documented elsewhere in the RPG guide. However, this appendix allows abbreviated processes to be used in specific phases of the Navy RMF process to meet the unique needs of the Navy community as it pertains to IATT authorization.

ICT is a broad term used to define the various IT and communication systems implementations within the Navy. It includes applications, systems, networks, enclaves, IT services, and cloud instances and the data they process that require an AO authorization. This term is used throughout this appendix for brevity purposes but not meant to define every type of information system/IT type used in the Navy.

This appendix describes two profiles that can be used by the Navy RMF community to support IATT authorization efforts¹⁰:

1. Profile 1 – Standard IATT
2. Profile 2 – Urgent Deploy and Test (UDT) IATT

The streamlined IATT process (that the above profiles leverage) utilizes a standardized categorization and control set described below and as such it is not required for usage within Navy. This is meant as an option to be leveraged to expedite IATT processing, however in some cases programs may choose to utilize the full IATT process with individualized categorization and control sets in order to maximize reuse of documentation for future ATO requests.

I.2. Objectives

The objectives of this appendix include:

- Provide a streamlined RMF IATT customized workflow to improve processing times for AO approval.
- Provide a security control set for the Navy community to satisfy IATT authorization requirements. This security control set balances PM/SO/PMO Level of Effort (LOE) to achieve IATT authorizations and Cybersecurity requirements using best practices from DoD partners and the Center for Internet Security (CIS).
- Provide clarifying terms and environmental considerations to the Navy community in support of IATT project planning efforts.
- Identify a standardized IATT Test Plan template for use by the Navy RMF community to reduce ambiguity and lack of standardization across the Navy community. The IATT Test

¹⁰. Both profiles offer a reduced Level of Effort (LOE) in support of an IATT authorization, but the use of the UDT profile is to meet the needs of a small set of ICTs.

Plan is designed to complement the Security Plan and other artifacts in eMASS intended to capture the overall test preparation, planning, objectives, scope, timeframe, and the preliminary cybersecurity assessment conducted in support of support the IATT assessment and authorization request.

- To provide a process mechanism that can support Flag/SES level ICT testing in operational environments that have a "speed to capability" requirement to field quickly for testing¹¹.

I.3. Terminology

The terms identified below are provided to assist the Navy community and to provide context in support of the IATT authorization efforts.

Operational Environment: The Operational Environment is any element of the Defense Information Systems Network (DISN) (DISAs portion of the DoDIN, primarily SIPRNET/NIPRNET) but not limited to those operational transport services as defined in Joint Pub 3-12 and DISN Connection Process Guide series.

DoDIN: The set of information capabilities and associated processes for collecting, processing, storing, disseminating, and managing information on demand to warfighters, policy makers, and support personnel, whether interconnected or stand-alone (DODIN-N is the Navy portion of the DODIN).

Live Data or Real Data: Live or real data is data that comes from the DISN operational environment or operational IT in the form of ICT.

Standalone Environment: Generally, individually managed devices or ICT (e.g., desktops, laptops, smartphones, tablets) with no interface to other separately authorized ICT and is contained physically and logically in one or more standalone locations. Data flows and Ports, Protocols, and Services (PPS) are provided within its authorization boundary with no external interfaces to outside entities – to include the Internet, even at the local level. Standalone environments are the least exposed and are typically simple to understand and implement¹².

Managed/Enterprise Environment: Refers to centrally managed ICT (e.g., Servers, printers, desktops, tablets, smartphones) that involves administrative control over configuration settings on devices and have external interfaces outside of its authorization boundary to other ICT at the same local site or remotely to or across LAN/WAN or other transport mechanisms that have been authorized or assessed separately. Managed environments are more restrictive than standalone environments. They tend to implement several layers of defense¹³.

I.4. RMF Stakeholder Key Assumptions

The intent of the streamlined processes in this appendix is to support a standardized and expedited IATT authorization from the AO. To allow a fast-tracked path for approval, the AO checkpoint is moved to the very end of the process, or in the case of the UDT profile, totally removed to improve RMF IATT processing times in support of speed to capability requirements.

¹¹ Research, Development and Test Environments (RDT&E) that operate within zones B, C, or D does not require an IATT authorization unless interfacing or connecting to an operational environment or determined to be a requirement by the cognizant AO.

¹² For RMF purposes, ICT in standalone environments, as defined above, is not considered to be connected.

¹³ For RMF purposes, ICT in managed/enterprise environments as defined above are considered to be connected ICT.

Both IATT profiles described in this appendix support this function in addition to the other efficiencies noted within. Assumptions for successful IATT events include:

- AO expectations that RMF downstream stakeholders have adhered to procedures and workflows defined in this guide
- Navy PSO has implemented appropriate training, and quality assurance checks to ensure ICT is ready for IATT authorization
- RMF IATT package ATD will be impacted if the downstream stakeholders fail to meet established standards, processes, and procedures (reduced quality). Failed quality reviews that do not allow the AO to make an informed authorization decision may result in reduced authorization timeframes, with stipulations to the SO/PMO to fix cybersecurity defects, or be issued a DATO, if the ICT has failed critical RMF requirements and/or operational risk is unacceptable.
- AO decision is critical to successful and secure operations of ICT that require AO approval; the PSO entity must ensure downstream RMF stakeholders have fully executed RMF activities following established policies and procedures for a successful end goal of AO authorization

I.5. IATT Profiles (Standard and UDT Profiles)

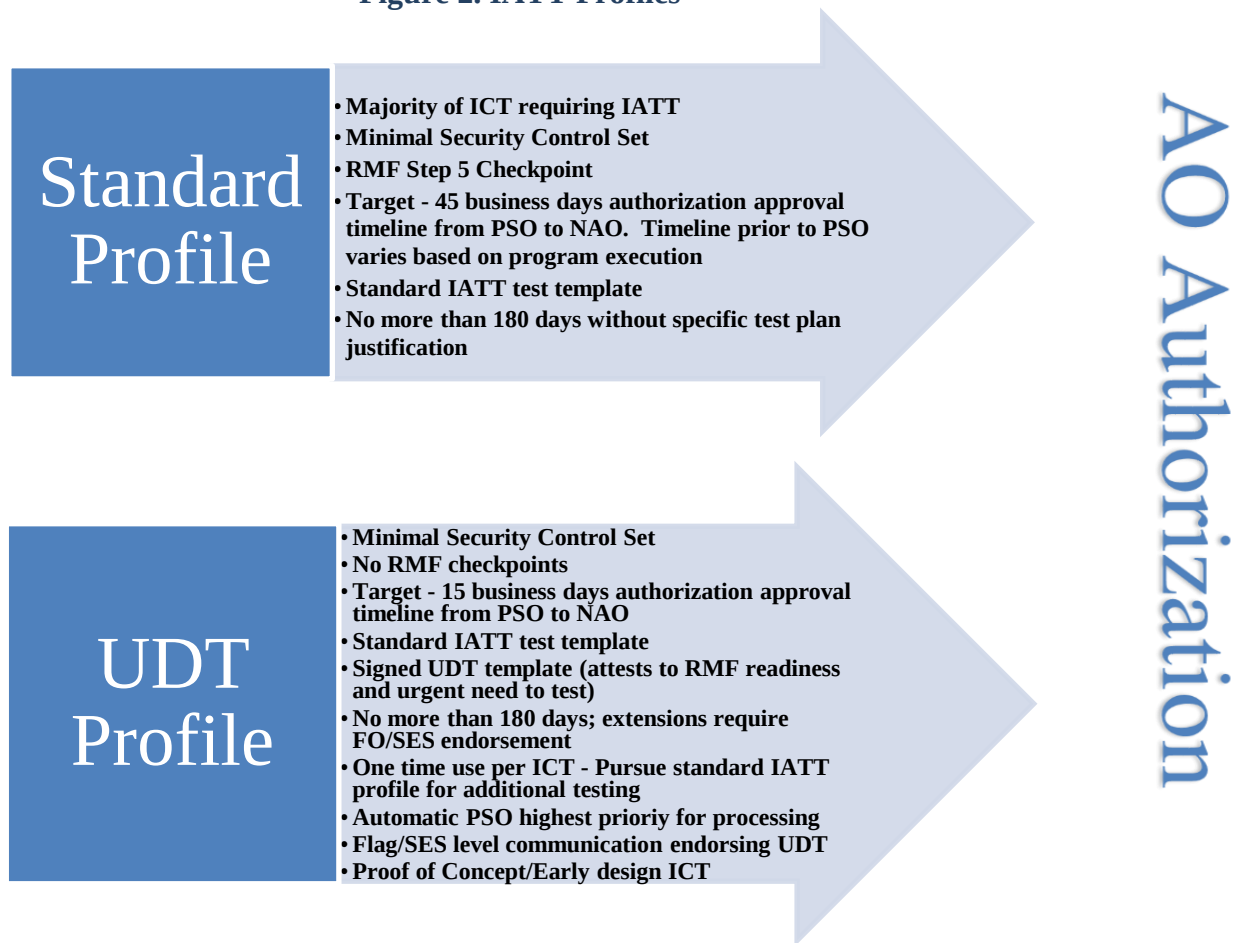
If the environment in which the testing is taking place is not connected to the operational networks and no live data is being utilized, and is located in an Research Development Test and Evaluation (RDT&E) or Development environment then an IATT is not required and approval to execute testing shall be documented and approved by the local CIO/ISSM. This does not apply if the system is processing data that is considered sensitive in nature (e.g., PII) and requires specific protections in accordance with DoD/Navy policy. In this case, an IATT from the cognizant AO is still required.

If an IATT is required, Navy stakeholders shall consider two IATT profiles when planning RMF activities in support of an IATT authorization.

- The standard IATT profile is what the majority of Navy users are required to use for ICT that require an IATT authorization. This profile allows for an expedited review for AO approval but requires an RMF Step 5 Checkpoint before the final authorization decision.
- The second IATT profile is the UDT profile, which allows for a fast-tracked IATT authorization for ICT testing with Flag/SES-level endorsement in operational environments that have a "speed to capability" requirement. The UDT profile supports a streamlined AO approval to deploy and test in an operational environment.

Some key tenants of the two profiles are listed in Figure 2.

Figure 2. IATT Profiles



I.6. IATT Profile Qualification Criteria

RMF stakeholders must consider carefully appropriate IATT profiles to use for ICT requiring an IATT authorization to prevent delay of the AO approval. The UDT process intends to address the need of the Navy community to expedite approval of ICT that meets acquisition definition of initial design and/or proof of concept that have Flag/SES level interests to deploy quickly to test in an operational environment. Planners must consider using the standard IATT profile for a majority of their IATT efforts since overuse of the UDT process will burden RMF stakeholder queues and dilutes the purpose of this profile. Additionally, incorrect profile use will delay AO approval and require rework at all levels to correct process discrepancies. PM/SO must consider the below preliminary questions before submission to the SCA/AO and commencing authorization efforts as it pertains to IATT profiles.

- Does the ICT have documented Flag/SES level interest (either via memo or email to NAO) and urgent requirement to test within or interface with an operational environment? Yes, consider use of the UDT profile
- Is the system hosted in RDT&E environments and designated as a zone A, B, C, or D? Yes, use the standard profile

- Is the test environment a build and test only with no requirement to use live or real data? Yes, use the standard profile unless the test environment is RDT&E Zone C or D in which case an IATT may not be required.
- Is the ICT aligned with a program of record (POR) or requires an IATT to test an upgrade to a currently authorized system? Yes, use the standard profile
- Is the ICT software development effort employing Agile methodology on a currently authorized ICT? Yes, use the standard profile
- Is the ICT software development effort employ Agile methodology on a currently authorized ICT that requires immediate ability to test with Flag/SES level interests confirmed by the PMO/PSO? Yes, consider use of UDT
- Is the ICT governed by DoD Acquisition Process (Major Defense Acquisition Program or Major Automated Information System (MAIS)? Yes, use the standard profile

Note: Agile methodologies used by SO/PMOs as part of the SLDC should coordinate with AO/SCA on their agile process and cycles and “continuous security” practices to receive AO approval, which may reduce the number of IATT events for their ICT.

Timeline targets defined in this appendix for IATTs do not account for the time required for the development of the IATT RMF product prior to submission to the SCA. They also depend heavily on quality RMF products to produce a desired risk assessment and authorization outcome. It must be noted that any IATT ICT assessed as HIGH/VERY HIGH risk will not move forward for an IATT authorization and risk issuance of a DATO if not adjudicated by appropriate RMF stakeholders.

I.7. IATT RMF Security Controls

The security controls defined in Table 18 are used for ICT that require an IATT authorization and are applicable to all Navy ICT that choose utilize the expedited IATT process. Table 18 is the security control baseline that applies to all IATTs. These controls are identified as “best practice” security controls based on evaluation of other DoD agencies security control requirements and Center for Internet Security (CIS) benchmarks. The security controls identified for Navy IATT balances the need to deploy secure ICT while ensuring an adequate Level of Effort as it pertains to cost and resources for ICT pursuing a test event. The security controls listed in Table 18 do not prevent appropriate tailoring as allowed in the RMF process by any RMF stakeholder as part of their Cybersecurity strategy and does not relieve the SO/PMO from meeting mandated statutory or other higher level guidance as it pertains to specific information types that require specific cybersecurity requirements. For reference, selection of the Critical Security Control Set Overlay will set the baseline in accordance with Table 18.

Table 18. Applicable Security Controls for IATT

Control Family	Applicable Security Controls
Access Control (AC)	AC-1, AC-2, AC-2(1), AC-2(2), AC-2(3), AC-2(4), AC-2(7), AC-2(10), AC-2(11), AC-3, AC-4, AC-5, AC-6, AC-6(2), AC-6(10), AC-7, AC-11, AC-12, AC-17, AC-17(2), AC-17(3), AC-18, AC-19, AC-20, AC-20(1), AC-23, AC-24

Accountability, Audit, and Risk Management (AR)	AR-2
Audit & Accountability (AU)	AU-2, AU-3, AU-4, AU-5, AU-6, AU-7, AU-8, AU-9, AU-10, AU-11, AU-12, AU-13, AU-14
Awareness & Training (AT)	AT-3*, AT-4*
Configuration Management (CM)	CM-1*, CM-2*, CM-3*, CM-5*, CM-6, CM-7, CM-7(3), CM-8*, CM-9*, CM-10, CM-11*
Contingency Planning (CP)	CP-9*, CP-9(3) *, CP-10*
Identification and Authentication (IA)	IA-2, IA-2(1), IA-2(2), IA-2(3), IA-2(4), IA-3, IA-4*, IA-4(2) *, IA-5, IA-5(1), IA-5(2), IA-5(5), IA-5(6), IA-5(7), IA-5(11), IA-10*
Incident Response (IR)	IR-2*, IR-3*, IR-4, IR-5, IR-6, IR-7*, IR-8, IR-9*, IR-10*
Maintenance (MA)	MA-4*
Media Protection (MP)	MP-3, MP-4, MP-5
Personnel Security (PS)	PS-2, PS-3, PS-3(1), PS-3(2), PS-3(3), PS-4, PS-4(1), PS-4(2), PS-5, PS-6, PS-6(2), PS-6(3), PS-7, PS-8
Physical and Environmental (PE)	PE-2, PE-2(3), PE-3, PE-3(1), PE-3(2), PE-3(3), PE-3(4), PE-3(5), PE-4, PE-5, PE-5(3), PE-6, PE-6(1), PE-6(4), PE-8, PE-10, PE-11, PE-12, PE-13, PE-14, PE-15, PE-17*, PE-19*, PE-19(1) *
Planning (PL)	PL-2, PL-8
Program Management (PM)	PM-5*, PM-6*, PM-14*, PM-16*
Risk Assessment (RA)	RA-2, RA-3, RA-5, RA-5(5), RA-6
Assessment and Authorization (CA)	CA-2, CA-2(1), CA-3, CA-3(2), CA-5, CA-6, CA-7*, CA-8*, CA-9*
System and Communication Protection (SC)	SC-7, SC-7(18), SC-8, SC-12*, SC-13*, SC-15, SC-16*, SC-17*, SC-18, SC-20, SC-21, SC-22, SC-23, SC-24*, SC-28, SC-31*, SC-34*, SC-39, SC-40*, SC-41*, SC-44*
System and Information Integrity (SI)	SI-2, SI-2(2), SI-3, SI-4, SI-4(4), SI-4(23), SI-6*, SI-7, SI-8, SI-10, SI-10(3), SI-11*, SI-15*, SI-16
System and Services Acquisition (SA)	SA-3*, SA-4*, SA-4(6)*, SA-4(7) *, SA-9*, SA-10*, SA-11, SA-13*, SA-15*, SA-16*, SA-17*, SA-18, SA-20*, SA-21*, SA-22

* Controls marked in Table 1 with an “*” may be tailored as not applicable

I.8. Process Flows and RMF Authorization Process Steps

The processes defined in this appendix require streamlined processing of ICT for IATT in support of their testing schedules and objectives. Figure 3 is a snapshot of the streamlined process workflows and timelines established for the two IATT profiled identified in this appendix. RMF stakeholders are reminded that the timelines noted are target timelines and are based on a high quality RMF IATT package that has met all requirements of established processes for IATT decision by the AO. The estimated timelines for the UDT (15 days) and the Standard (45 days) IATT processes are measured from the moment the ISSM submits the IATT package to moment the AO approves it. Any time spent in efforts prior to the ISSM submission event do not count as part of the IATT streamlined process. For the UDT profile, PSO checkpoint is zero days because no checkpoints are required for the UDT. For the standard profile, no Step 2 Checkpoint is required. In eMASS only 2 workflows are completed for an IATT: SAP and IATT.

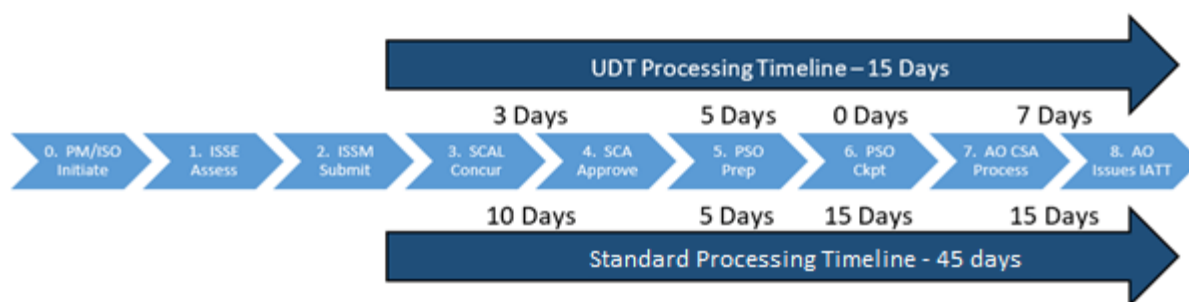


Figure 3. IATT Workflow with Processing Timelines

Table 19 provides description of RMF process steps to achieve an IATT authorization.

Table 19. RMF IATT Authorization Process Steps

RMF Step	Process or Document Change	Artifacts
Steps 1 & 2		
Categorize System and Select Security Controls	- PM/SO initiate IATT workflow in eMASS - PM/SO selects whether to use the standard IATT profile or the UDT profile - If the program selects not to use the UDT profile or the standard IATT profile, they must: - o Categorize the system as applicable to the test event. Include only what data types are stored, processed, transmitted during the test event, and what level their C-I-A should be protected (i.e., Integrity during test event may be Low but in operation may be Moderate or High). - o Establish a baseline control set based on the categorization, then add the Critical Security Control	1) Approved Categorization 2) Security Plan 3) IATT Test Plan

	Set overlay, then any additional overlays as required. Tailor security controls for individual system/test event - Any planned functional testing should include in the Test Plan, which is separate from the Security Assessment Plan (SAP). Utilize published Test Plan template and complete necessary sections for a specific test event type. - Note: SLCM strategy document not required.	
Step 3		
Implement / Test Security Controls	- ISSE initiates the SAP workflow in eMASS and gains SAP approval before entering RMF Step 4 - ISSE/ISSM implement approved security controls - ISSE executes SAP and assesses applicable security controls (Validator participation is encouraged but not required) - ISSE advances IATT workflow to ISSM in eMASS	4) Security Assessment Plan (SAP)
Step 4		
Assess Security Controls	- ISSM reviews assessment results and completes risk assessment in eMASS (Validator participation encouraged but not required) - ISSM/ISSE complete SAR Executive Summary - ISSM advances IATT workflow to SCAL in eMASS - SCAL concurs with assessment and advances IATT workflow to SCA in eMASS - SCA signs SAR and advances IATT workflow to PSO in eMASS	5) Completed Risk Assessment 6) SAR Executive Summary
Step 5		
Authorize	- PSO preps package and schedules checkpoint - PSO advances IATT workflow to PSO Checkpoint step in eMASS - Checkpoint not required for UDT IATT submissions. A checkpoint may be scheduled at the PSO discretion with input from AO/PM. - PSO advances IATT workflow to AO CSA in eMASS - AO CSA processes for signature and advances IATT workflow to AO in eMASS - AO signs IATT completing IATT workflow	7) Signed SAR 8) Signed Authorization
Step 6		
Monitor	- The PM/SO maintains system integrity/security posture throughout the test event - ISSE update Security POA&M as necessary - The system needs to disconnect once the IATT event is complete. - The system sponsor shall ensure the system under test is physically removed from the network, powered off, and halts all operations unless approved to remain on-site by AO. The site ISSM shall record this event as an official record.	9) Updated POA&M

I.9. Business Rules & Checklist

The templates listed below are available on the USN RMF Portal in the Templates to support Navy IATT efforts.

- IATT Test Plan Template
- IATT Checklist
- UDT Form (required for use to leverage the UDT Streamlined IATT Process)

Appendix J - Financial Management Overlay

J.1. Background

Department of the Navy Chief Information Officer (DON CIO) and the Assistant Secretary of the Navy (Financial Management & Comptroller) Financial Policy and Systems (FMP) jointly developed the Financial Management (FM) Overlay to address the most critical control failures identified Navy-wide during the Fiscal Year 15 Independent Public Accountant's audit.

J.2. Purpose

While RMF is the overall cybersecurity guidance for the DON, the FM Overlay enhances security by providing supplemental controls to meet audit requirements for relevant systems as defined by Financial Improvement and Audit Readiness (FIAR) Guidance, the annual requirement for System and Organization Control (SOC-1) Report, and FMP. The FM Overlay introduces additional requirements to cybersecurity baseline security controls. Due to some additional requirements established by the FM Overlay, coordination is required between FMP and SCA to ensure cohesive deployment of RMF and the FM Overlay. This framework guides the respective organization's (FMP and SCA) roles and responsibilities during the validation of the FM Overlay controls for audit-relevant systems.

J.3. Scope

This FM overlay applies to Assessment & Authorization (A&A) efforts for all DON audit-relevant systems, as depicted in Figure 8.

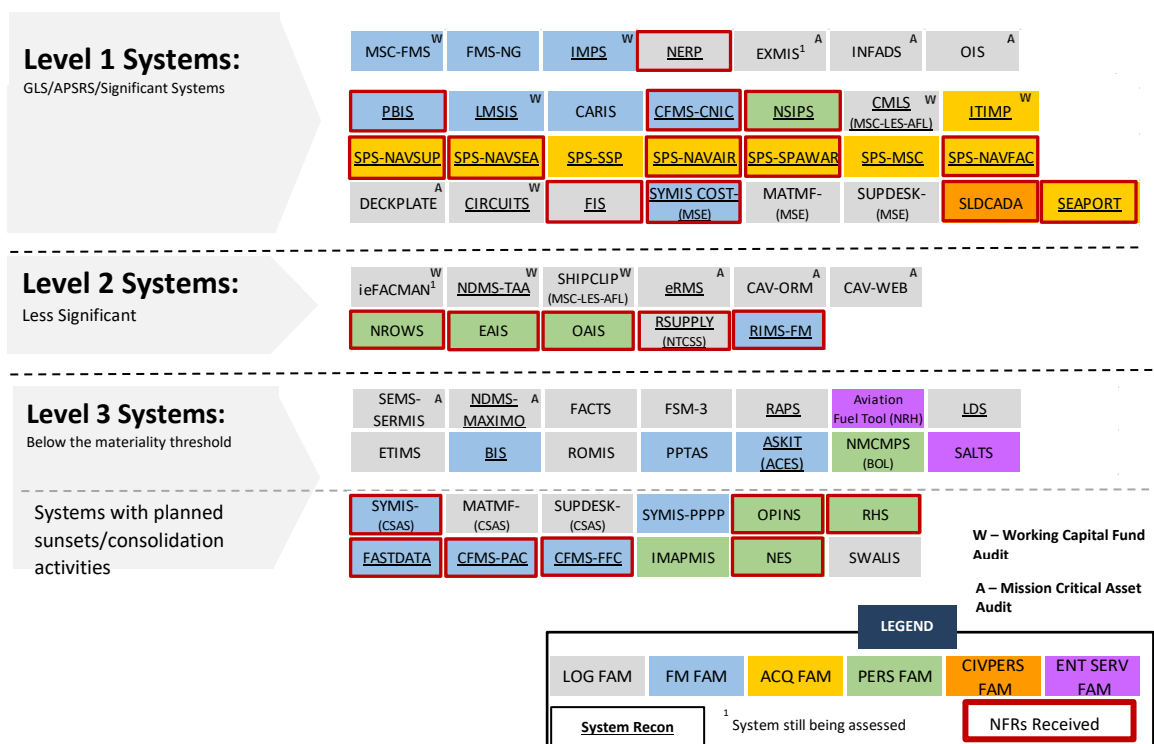


Figure 4. FM Audit-Relevant System Inventory

J.4. Roles and Responsibilities

J.4.1. Financial Policy and Systems

FMP is responsible for the policy and oversight of FM Overlay requirements. FMP will provide guidance and support to system owners and key stakeholders involved in adopting the FM Overlay. FMP Validators may be required to assess the FM Overlay controls to support the FMO; however, for the purposes of a Navy A&A effort, the NQV is qualified to assess these controls.

J.4.2. Financial Management Validator

The FMP-provided Validator is responsible for assessing and validating the implementation of FM Overlay controls on behalf of the FMP; however, for the purposes of a Navy A&A effort, the NQV is qualified to assess these controls. In addition to providing inputs and guidance related to the FM Overlay for the system's RMF artifacts, the FMP-provided Validator works with the system assigned SCA Validator to complete assessment of the controls during Step 4 of the RMF process.

J.4.3. Navy Security Controls Assessor

The Navy SCA is responsible for evaluating risk and recommending authorization decisions for audit-relevant information systems as part of the RMF A&A process.

J.4.4. Office of the Chief of Naval Operations for Information Warfare (OPNAV N2N6)

OPNAV N2/N6 is only involved as a broker of this overlay and is not required to provide any additional resources. FMP is responsible for providing additional resources as necessary.

J.5. Execution

In order to ensure successful implementation of the FM Overlay, the following guidance will be followed:

J.5.1. Financial Policy and Systems

FMP will identify DON information systems where the FM Overlay applies. The list of audit-relevant systems must be continually maintained. A cumulative list will be maintained on the USN RMF Portal.

FMP will maintain documentation that provides guidance on the implementation of the FM Overlay, and make personnel available to provide guidance and support for system owners that are in the process of implementing FM Overlay requirements.

FMP will assign and make available FMP-provided Validators to assess compliance of the FM Overlay on behalf of the FMP.

FMP will ensure that FMP-provided Validators are certified as per the *Navy Qualified Validator (NQV) Slicksheet* dated June 2022.

When performing the additional testing and assessment procedures required by the FM Overlay, FMP-provided Validators will adhere to DON Enterprise IT Control Standards and FM Overlay Validation Procedures. The FMP-provided Validator will be responsible for assessing and recording FM Overlay controls as Compliant Official (CO) or Non-Compliant Official (NCO) at the conclusion of testing within eMASS. In situations where a security control assessment procedure fails solely due to an additional requirement added by the FM Overlay, the FMP-provided Validator will:

- a. Consider the compliance of the security control's baseline requirements when providing risk severity feedback to the system assigned SCA Validator to minimize impact that the FM Overlay Controls may have on the A&A Process.
- b. In cases where an agreement cannot be reached, the FMP-provided Validator will accept the system assigned SCA Validator's risk assessment recommendation for the SAR. Disagreements for the risk level of failed controls will be documented on the relevant Risk Assessment (RA) security control prior to SCA's review.

Upon completion of FMP-provided Validator's assessment, FMP will review the FMP-provided Validator's test results and provide an FM Endorsement Memorandum that summarizes compliance with FM Overlay requirements. The FM Endorsement Memorandum will be included as an artifact in eMASS.

FMP and SCA will coordinate any modifications to this agreement with OPNAV N2N6 required by either party.

J.5.2. Navy Security Control Assessor Agreement

The Navy SCA will consider the information contained in the FM Endorsement Memo to assess the final risk level for the audit-relevant system where the FM Overlay has been applied.

The Navy SCA will coordinate with FMP to answer questions regarding FM Overlay requirements or the recommended risk levels provided by the FMP-provided Validator for NCO FM Overlay security controls.

J.6. Execution

This process is to be executed in accordance with the DON CIO & FM&C FM Overlay Guide for eMASS, posted on the USN RMF Portal. The up to date list of systems impacted by this process and guidance is also on the USN RMF Portal, titled “Audit Relevant Systems.”

Table 20. FM Document Guide

Document	Location
DON Enterprise IT Control Standards	https://portal.secnav.navy.mil/orgs/OPNAV/N2N6/DDCION/N2N6BC4/RMF/Shared%20Documents/Forms/AllItems.aspx
DON Financial Management (FM) Overlay Validation Procedures	
FMP-10 Audit-Relevant System List	

Appendix K - Streamlined Risk Management Framework (RMF) Review Process

1. The following review process optimizes the Navy RMF A&A process by providing the option for a Streamlined RMF review to expedite RMF ATO decisions. This process applies to Program Management Offices (PMO) under the NAO and PSOs under an FAO.

2. This streamlined review process will allow RMF packages submitted by qualifying PMOs or PSOs to bypass the duplicative A&A package quality reviews normally performed when a package is submitted beyond a PMO or PSO. Through this streamlined review process, the PMO or PSO will bear the responsibility for RMF package adherence to RMF policy and Quality Assurance in accordance with the RMF Standard Operating Procedures (SOPs) found at OPNAV RMF KS. The Echelon II portfolio owner retains the responsibility to set package processing priorities for respective AO, for example to support operational mission imperatives or other exigent circumstances.

3. PMO/PSO participation in this streamlined review process is at the discretion of and will be managed by the applicable Echelon II command. PMO/PSO eligibility shall be determined based on a documented track record of success in submitting quality RMF packages that meet A&A package standards. Implementation and management of this process shall be managed by the applicable Echelon II command and shall not add to or deviate from the intent of this policy.

4. To participate in the Streamlined RMF Review process, PMOs or PSOs must have:

a. A documented and proven track record of submitting quality packages based on RMF SOP findings;

b. Request approval from their Echelon II command;

c. Attend provided RMF Standard Operating Procedure (SOP) training outlined in reference (ab);

d. Nominate and officially document who the primary and secondary “submitter” will be within the PMO or PSO. If the “submitter” changes, the PMO or PSO must notify the Echelon II command;

e. Provide a completed SOP review checklist with each RMF package submission.

5. Under FAO, an approved PSO will submit any RMF packages directly to the FAO Designated Representative (see Figure 5: Step 2 Streamlined Risk Management Framework Review Process and Figure 6: Step 5 Streamlined Risk Management Framework Review Process).

6. Under NAO, PSOs will submit any RMF packages received by an approved PMO directly to the AO CSA (see Figure 5: Step 2 Streamlined Risk Management Framework Review Process and Figure 6: Step 5 Streamlined Risk Management Framework Review Process).

7. The Streamlined RMF review process is a privilege, and the authorizing Echelon II command may revoke participation if:

a. Required SOP training is not completed as required by all personnel assigned to conduct these reviews; or

b. Completed SOPs are not provided with each submission; or

c. The AO documents reduced quality in packages for three sequential submissions and/or PMO/PSO fails to process RMF package submission in accordance with reference (ab). It is at the discretion of the AO to require PSO review of a RMF package due to non-compliance with Navy policy or other cybersecurity issues that must be addressed by the Echelon II command as part of their portfolio responsibilities.

8. When bypassing the duplicative compliance review under this streamlined review process, PSOs and Echelon II's shall continue to manage eMASS workflows and prioritize RMF package submissions to the AO for processing and ATO decision. Additionally, High Risk authorization requests and CARs will still require PSO review and validation that the appropriate endorsements and artifacts have been provided to support these approvals.

Figure 5: Step 2 Streamlined Risk Management Framework Review Process

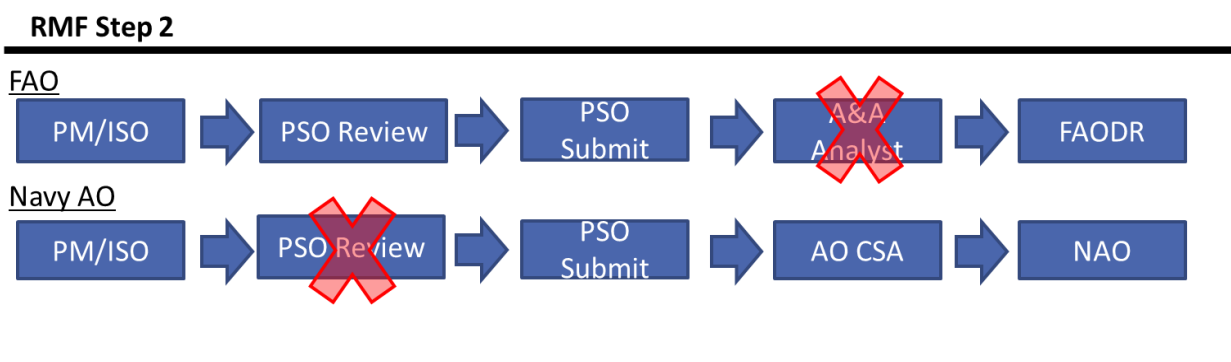
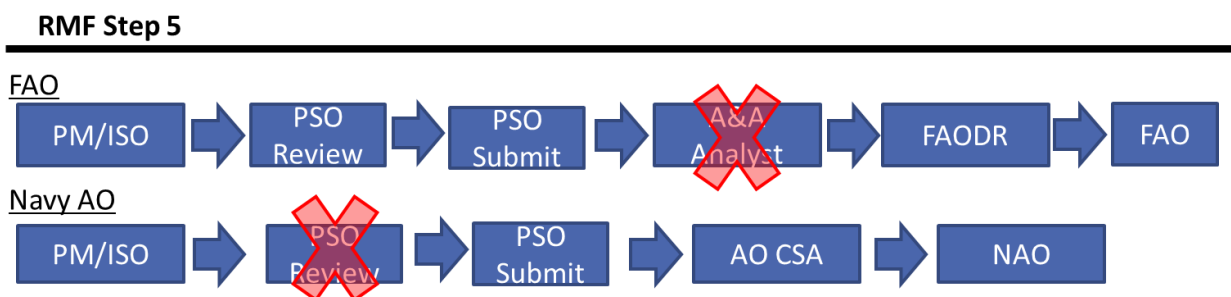


Figure 6: Step 5 Streamlined Risk Management Framework Review Process



Appendix L - Streamlined Reauthorization Process

L.1. Applicability

This guide applies to all Navy IT – without exception – that receive, process, store, display, or transmit DoD information, and operate at the GENSER Secret level and below and have a valid RMF Step 5 Authorization Decision (not-expired). This guide does not apply to IT that has been granted an ATO with Conditions for High/Very High residual risk requiring Component-level approval to operate, CARs, or IATT (with less than three-year authorization).

L.2. Entry and Exit Criteria

Entry Criteria:

- Valid ATO (not expired)
- Approved SLCM Strategy
- Up to date VRAM Record
- Completed ASRs per SLCM
- Signed SAR

Exit Criteria:

- New Authorization (will not exit step 6, but start the RMF Step 5 process over)
- DATO/Decommission

Note: According to the Annual Security Review (ASR) guidance, A Navy Qualified Validator (NQV), while recommended, is not required for the annual security review.

L.3. Reauthorization Review:

At year three of an authorization cycle, a reauthorization is required to continue operating. Navy IT that have executed their approved SLCM, maintained their VRAM records, updated their SP and POA&M to reflect changes to system baseline, and completed ASRs per their approved SLCM can skip to Step 4 in the RMF process for their ASR for Year 3 to conduct a new assessment and obtain a new authorization.

L.3.1. Review VRAM Record

Who: PM/SO, ISSM, ISSO, ISSE

What: The program will update the VRAM IAVA and Cyber Directives by ‘Acknowledged Date Required’. The program must comply with the Cyber Directives by ‘Required Date’ regardless of the Security Control Frequency selected in eMASS. Current scans must be uploaded and make sure assets listed in eMASS package match what is in VRAM.

Where: VRAM

How: The ISSO, working with the ISSM and PM/SO, reviews the VRAM record for IAVA and Cyber Directive compliance.

L.3.2. Approve Annual Security Review (Year 3)

Who: SCA

What: The SCA reviews the residual risk. If the residual risk remains the same or is lower, the SCA will approve the appropriate eMASS step(s).

Where: eMASS

How: Update the SAR Executive Summary in eMASS (see below). The SCA uses the SAR Executive Summary to document the residual risk of the non-compliant security controls and any continuous monitoring activities noted in accordance with the SCA ASR minimum requirements during the annual security review. The SAR is completed once all of the findings have been entered and the security controls compliance status is finalized. A digitally signed SAR (by SCA) must be completed for each annual review. A new SAR Executive Summary is required for Year 3 of the authorization.

SAR Executive Summary

The ISSM/ISSE will draft a SAR Executive Summary for assessment by the NQV prior to submission to the SCA. The SAR Executive Summary must contain the following points:

- An assessment of overall system cybersecurity risk (High, Moderate, or Low), and identify the key drivers for that assessment
- A synopsis of the SAR to include an overall recommendation for authorization. This analysis shall include any changes in the security posture of the system from the previous review.
- Recommendations for correcting or accepting any deficiencies

L.3.3. Authorization Decision

Who: AO, SCA

What: For Year 3 annual security review, the AO issues an authorization decision based on the compliance of the SLCM strategy, the up-to-date SAR, validation of the package record, supporting documentation submitted in eMASS.

Where: eMASS

How: The SCA submits the digitally signed SAR and SAR Executive Summary in eMASS and moves the workflow up to the Echelon II PSO for Triage (if required). The Echelon II PSO schedules checkpoint meeting (if required) and moves the package to the AO CSA (or equivalent role). The AO CSA (or equivalent role) will review the BOE, draft Authorization Letter, and send the package to the AO for final approval and signature of the Authorization.